ĐẠI HỌC QUỐC GIA HÀ NỘI
TRƯỜNG ĐẠI HỌC CÔNG NGHỆ



Đỗ Đình Đô, Nguyễn Chí Dũng, Đỗ Hoàng Ân

TÌM HIỂU VỀ KIẾN TRÚC BẢO MẬT ZERO TRUST (ZTA) VÀ GIẢI PHÁP ZTNA

BÀI TẬP LỚN MÔN MẬT MÃ VÀ AN TOÀN THÔNG TIN

Ngành: Công nghệ thông tin

HÀ NỘI – 2026

ĐẠI HỌC QUỐC GIA HÀ NỘI
TRƯỜNG ĐẠI HỌC CÔNG NGHỆ

Đỗ Đình Đô, Nguyễn Chí Dũng, Đỗ Hoàng Ân

TÌM HIỂU VỀ KIẾN TRÚC BẢO MẬT ZERO TRUST (ZTA) VÀ GIẢI PHÁP ZTNA

BÀI TẬP LỚN MÔN MẬT MÃ VÀ AN TOÀN THÔNG TIN
Ngành: Công nghệ thông tin

Cán bộ hướng dẫn: TS. Lê Thị Hợi

HÀ NỘI – 2026

Chương 1.
BỐI CẢNH AN TOÀN MẠNG VÀ MÔ HÌNH DỊCH CHUYỂN ZERO TRUST

1.1. Sự tiến hóa của hạ tầng mạng doanh nghiệp hiện đại

Hạ tầng Công nghệ thông tin (CNTT) của các doanh nghiệp hiện đại đang trở nên ngày càng phức tạp và phân tán. Một tổ chức ngày nay có thể đồng thời vận hành nhiều mạng nội bộ, các văn phòng chi nhánh từ xa với hạ tầng riêng biệt, kết hợp với lực lượng lao động làm việc linh hoạt từ xa và hệ thống dịch vụ đám mây đa dạng.

Chính sự phức tạp này tạo ra những thách thức lớn đối với khả năng kiểm soát của các phương pháp bảo mật mạng dựa trên vành đai truyền thống (*Perimeter-based Security*), bởi doanh nghiệp không còn sở hữu một ranh giới mạng vật lý duy nhất dễ dàng xác định. Hơn thế nữa, mô hình phòng thủ vành đai bộc lộ những hạn chế đáng kể: nếu kẻ tấn công vượt qua được bức tường lửa cửa ngõ, chúng có thể tiến hành di chuyển sang ngang (*Lateral Movement*) trong hệ thống mạng nội bộ mà ít gặp phải rào cản hay cơ chế phát hiện chuyên sâu.

Bối cảnh này đã thúc đẩy sự phát triển của một tư duy an ninh mạng thế hệ mới mang tên Zero Trust (ZT - Không tin tưởng ngầm định).

1.1.1. Sự bùng nổ của Điện toán đám mây và dịch vụ SaaS

Trong quá trình tiến hóa hạ tầng, sự bùng nổ của Điện toán đám mây và các dịch vụ Phần mềm như một Dịch vụ (*SaaS - Software as a Service*) đóng vai trò là tác nhân chuyển dịch cốt lõi thông qua 4 khía cạnh:

1. **Sự dịch chuyển sang hạ tầng Đa đám mây (*Multi-Cloud Migration*):** Doanh nghiệp chủ động chuyển dịch các tải công việc (*workloads*) từ trung tâm dữ liệu nội bộ (*On-premises Data Center*) sang vận hành trên các nền tảng điện toán đám mây công cộng như Amazon Web Services (AWS), Microsoft Azure, và Google Cloud Platform (GCP). Việc áp dụng các mô hình Hạ tầng dưới dạng Dịch vụ (*IaaS - Infrastructure as a Service*) và Nền tảng dưới dạng Dịch vụ (*PaaS - Platform as a Service*) khiến dữ liệu nghiệp vụ không còn nằm trong phạm vi bảo vệ vật lý thuộc quyền kiểm soát trực tiếp của doanh nghiệp.

2. **Sự phổ cập của các ứng dụng SaaS nghiệp vụ:** Các công cụ làm việc cốt lõi của tổ chức như Microsoft 365, Google Workspace, Salesforce hay Zoom được triển khai rộng rãi theo mô hình SaaS. Cán bộ nhân viên truy cập trực tiếp vào các ứng dụng này qua trình duyệt web trên nền tảng Internet công cộng, giảm dần sự phụ thuộc vào việc kết nối tập trung về máy chủ ứng dụng nội bộ qua mạng LAN truyền thống.
3. **Thay đổi bản chất luồng lưu lượng mạng (*Network Traffic*):** Tuyến truyền tải dữ liệu truyền thống theo mô hình tập trung (Người dùng $\rightarrow$ Mạng nội bộ $\rightarrow$ Trung tâm dữ liệu) dần được thay thế bởi mô hình kết nối phân tán (Người dùng $\rightarrow$ Internet công cộng $\rightarrow$ Dịch vụ Đám mây/SaaS).
4. **Hiện tượng giảm hiệu lực ranh giới bảo mật (*De-perimeterization*):** Do lưu lượng dữ liệu từ người dùng đến ứng dụng Đám mây/SaaS nhiều trường hợp đi thẳng qua Internet thay vì qua cổng kết nối gateway của trung tâm dữ liệu nội bộ, các cơ chế kiểm soát đặt tại chu vi trung tâm có thể mất khả năng quan sát trực tiếp một phần lưu lượng truy cập này, từ đó làm giảm hiệu quả giám sát của các thiết bị truyền thống như Tường lửa (*Firewall*) hay Hệ thống phát hiện và ngăn ngừa xâm nhập (*IDS/IPS*).

Tóm lại, sự kết hợp giữa hạ tầng Đa đám mây và các dịch vụ SaaS đã làm mờ ranh giới bảo mật vật lý duy nhất của doanh nghiệp, đặt ra yêu cầu chuyển dịch sang mô hình an toàn thông tin phù hợp hơn — Kiến trúc Bảo mật Zero Trust.

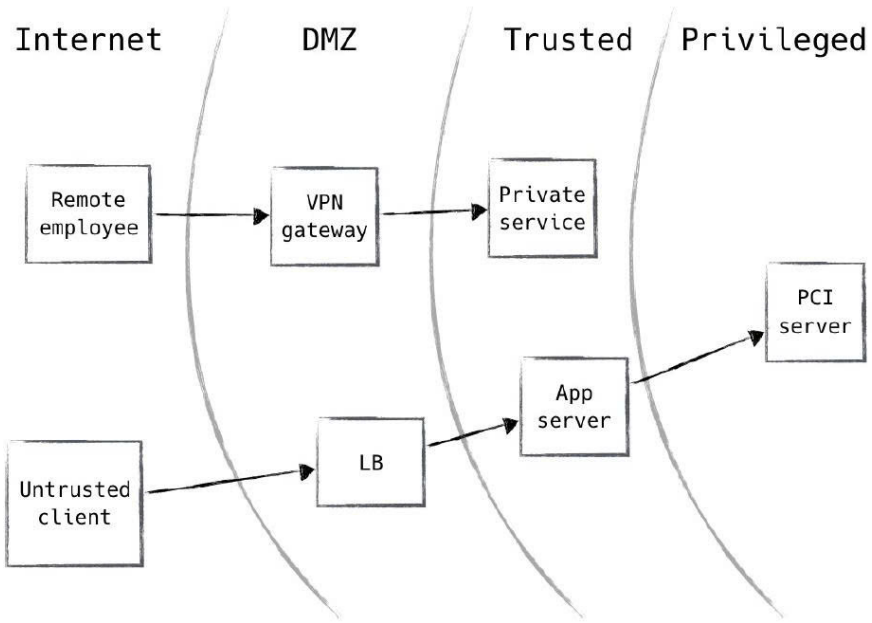
1.2. Phân tích lỗ hổng của Mô hình bảo mật chu vi (Perimeter Security)

1.2.1. Nguyên lý “Castle-and-Moat” và khái niệm vùng tin tưởng nội bộ

Mô hình phòng thủ mạng truyền thống vận hành dựa trên tư duy quân sự cổ điển mang tên “Lâu đài và Hào nước” (*Castle-and-Moat*). Trong mô hình này, tòa thành đại diện cho toàn bộ tài nguyên nội bộ của doanh nghiệp, còn bức tường thành và hào nước chính là ranh giới chu vi mạng đóng vai trò ngăn cách giữa môi trường bên trong và bên ngoài.

Như được minh họa trong Hình **??**, kiến trúc truyền thống phân chia mạng thành các vùng (*zones*) chứa cấp độ tin cậy (*Level of Trust*) tăng dần từ trái sang phải:

– **Mạng không tin tưởng (*Internet / Untrusted Zone*):** Nơi chứa các đối tượng bên ngoài như nhân viên làm việc từ xa (*Remote employee*) hoặc khách hàng chưa được xác minh (*Untrusted client*).



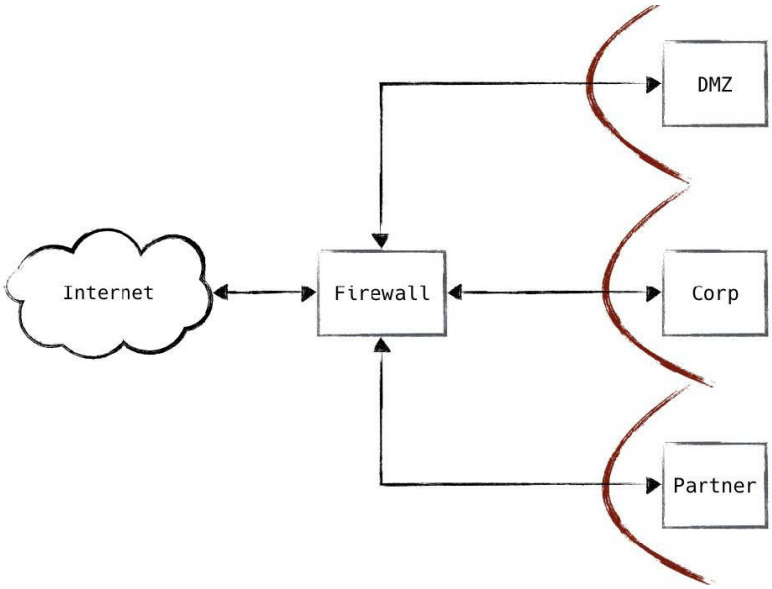
Hình 1.1. Kiến trúc bảo mật mạng truyền thống dựa trên phân vùng tin tưởng (Traditional Network Security Architecture).

– **Vùng đệm cách ly (*DMZ - Demilitarized Zone*):** Nơi đặt các thiết bị giao tiếp cửa ngõ như cổng kết nối VPN (*VPN gateway*) và bộ cân bằng tải (*Load Balancer - LB*) nhằm tiếp nhận luồng dữ liệu từ bên ngoài.
– **Vùng tin tưởng nội bộ (*Trusted Zone*):** Nơi chứa các dịch vụ nội bộ (*Private service*) và máy chủ ứng dụng (*App server*).
– **Vùng đặc quyền / Bảo mật cao (*Privileged Zone*):** Nơi lưu trữ tài sản nhạy cảm như máy chủ cơ sở dữ liệu thanh toán (*PCI server*), thường chỉ cho phép truy cập trực tiếp từ máy chủ ứng dụng.

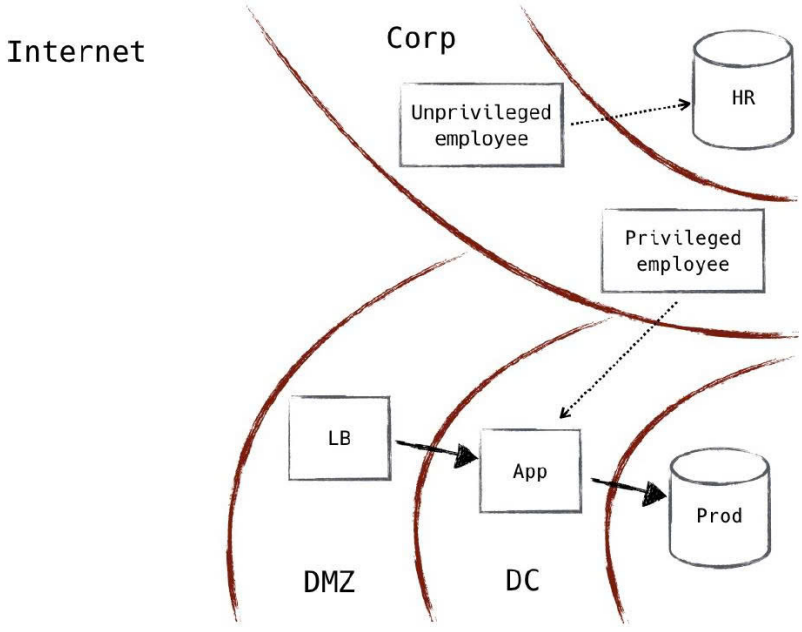
Bản chất cốt lõi của mô hình này nằm ở triết lý: "Niềm tin xác định mức độ bảo mật tối thiểu bắt buộc" (*Trust defines the minimum required security*). Khi một thiết bị nằm bên trong "Vùng tin tưởng nội bộ", nó thường mặc định được coi là an toàn, dẫn đến việc hệ thống giảm bớt các cơ chế kiểm tra chuyên sâu, nhiều luồng dữ liệu nội bộ không được mã hóa mặc định và hạn chế việc xác thực lại liên tục giữa các nút mạng ngang hàng.

Tuy nhiên, khi doanh nghiệp mở rộng kết nối với các bên thứ ba và mạng đối tác (*Partner Network*), bức tường lửa chu vi bắt buộc phải tạo các quy tắc ngoại lệ (*Rule Holes*) như trong Hình **??**. Sự tích tụ theo thời gian của các quy tắc ngoại lệ này làm suy yếu ranh giới bảo mật cứng ban đầu.

Hình **??** minh họa thực tế tương tác phức tạp giữa mạng doanh nghiệp (*Corp*) và trung tâm dữ liệu sản xuất (*DC*): nhân viên không có đặc quyền (*Unprivileged employee*) phải truy cập CSDL Nhân sự (*HR*), trong khi nhân viên đặc quyền (*Privileged employee*)



Hình 1.2. Sự tích tụ ngoại lệ tường lửa khi kết nối mạng văn phòng (Corp), vùng đệm (DMZ) và mạng đối tác (Partner).

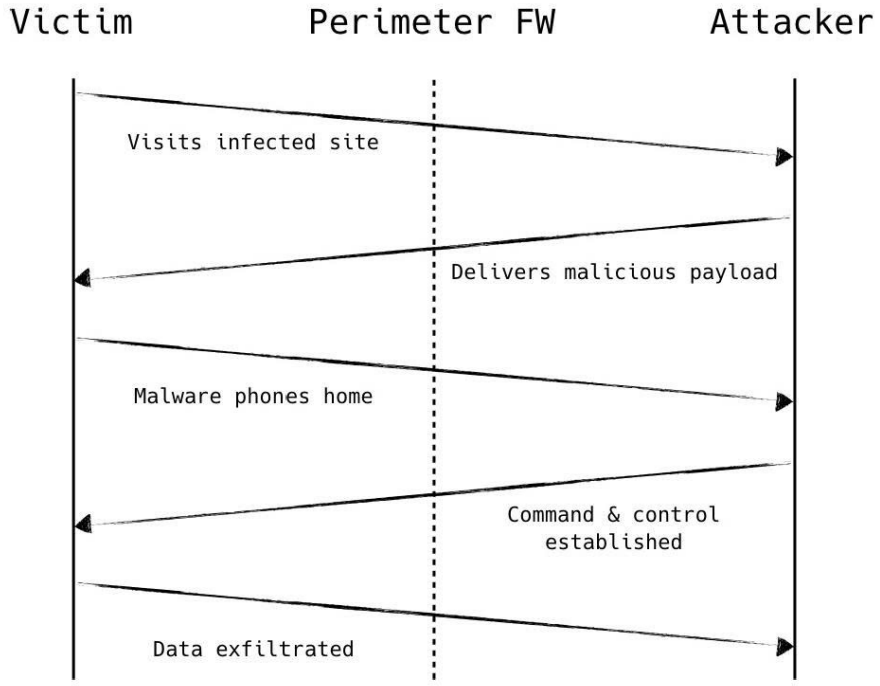


Hình 1.3. Sự tương tác kết nối chéo giữa Mạng văn phòng doanh nghiệp (Corp) và Trung tâm dữ liệu sản xuất (DC/Production).

kết nối trực tiếp vào máy chủ ứng dụng (*App*) tại trung tâm dữ liệu. Các luồng kết nối chéo này có thể biến phân vùng bảo mật thành điểm nhảy (*pivoting points*) cho kẻ tấn công nếu một thiết bị bị chiếm quyền kiểm soát.

1.2.2. Hạn chế của Tường lửa chu vi và kỹ thuật khai thác kết nối Outbound

Sự chuyển dịch sang bộ giao thức TCP/IP mang lại sự linh hoạt nhưng đòi hỏi cơ chế kiểm soát chặt chẽ. Mặc dù giao thức TCP/IP hỗ trợ kết nối hai chiều (*Bi-directional communication*), nhiều cấu hình tường lửa chu vi truyền thống vì lý do tối ưu vận hành thường áp dụng chính sách nới lỏng kiểm soát đối với luồng lưu lượng đi ra (*Outbound Traffic*) so với luồng đi vào (*Inbound Traffic*).



Hình 1.4. Tiến trình tấn công do máy nạn nhân khởi tạo kết nối đi ra (Outbound) vượt qua tường lửa chu vi.

Sơ đồ trình tự trong Hình **??** mô tả chi tiết cách kẻ tấn công lợi dụng chính sách luồng Outbound nới lỏng để xâm nhập qua tường lửa chu vi (*Perimeter FW*) thông qua một chuỗi kết nối do chính thiết bị nạn nhân (*Victim*) khởi tạo:

1. **Khởi tạo kết nối (*Visits infected site*):** Nạn nhân truy cập vào trang web bị lây nhiễm hoặc mở tệp đính kèm chứa mã độc từ email lừa đảo (*Phishing*).
2. **Tải mã độc (*Delivers malicious payload*):** Máy chủ của kẻ tấn công (*Attacker*) gửi gói dữ liệu độc hại về máy nạn nhân.

3. **Mã độc gọi về C2 (*Malware phones home*):** Mã độc thực thi trên máy nạn nhân, chủ động khởi tạo một kết nối TCP đi ra (*Outbound*) gửi về máy chủ điều khiển C2 (*Command and Control*). Do tường lửa cửa ngõ thường cho phép lưu lượng web Outbound thông thường đi qua, kết nối này dễ dàng được thiết lập.
4. **Thiết lập Command & Control (*C2 Established*):** Kênh điều khiển hai chiều được thiết lập hoàn tất dưới dạng đường hầm ngược (*Reverse Shell*), cho phép kẻ tấn công gửi lệnh điều khiển vào bên trong mạng nội bộ.
5. **Rút hái dữ liệu (*Data exfiltrated*):** Dữ liệu nhạy cảm thu thập được bị đóng gói và gửi ngược ra ngoài Internet thông qua chính kênh kết nối Outbound đã khởi tạo.

1.2.3. Sơ đồ tiến trình tấn công điển hình và nguy cơ di chuyển sang ngang

Một khi kẻ tấn công đã tạo được kênh giao tiếp ngược vào bên trong mạng doanh nghiệp, chúng bắt đầu tận dụng sự thiếu vắng các rào cản kiểm soát nội bộ để tiến hành mở rộng phạm vi ảnh hưởng qua các kỹ thuật cốt lõi:

- **Trích xuất thông tin xác thực (*Credential Theft*):** Thu thập trái phép tài khoản, mật khẩu, token xác thực hoặc khóa mã hóa.
- **Leo thang đặc quyền (*Privilege Escalation*):** Khai thác lỗ hổng hoặc dùng credential chiếm đoạt để nâng đặc quyền lên quyền quản trị (*Admin/Root*).
- **Di chuyển sang ngang (*Lateral Movement*):** Sử dụng quyền hạn và thông tin xác thực đã chiếm đoạt để dò quét, kết nối và truy cập sang các máy trạm và máy chủ khác trong mạng nội bộ.

Hình **??** phác thảo kịch bản tấn công thực tế gồm 10 giai đoạn thể hiện chuỗi liên kết của các kỹ thuật trên:

a) **Tấn công Phishing:** Kẻ tấn công nhắm mục tiêu vào nhân viên qua email lừa đảo.
b) **Chiếm máy & Đẩy Shell:** Máy công ty bị xâm nhập, mã độc đẩy ngược Shell ra ngoài.
c) **Di chuyển sang ngang (*Lateral Movement*):** Kẻ tấn công quét mạng nội bộ vốn không có rào cản kiểm soát.
d) **Định vị máy trạm đặc quyền:** Tìm thấy máy tính làm việc của lập trình viên/quản trị viên.
e) **Leo quyền & Cài Keylogger:** Leo quyền Admin cục bộ trên máy trạm và cài phần mềm theo dõi bàn phím.
f) **Đánh cắp mật khẩu:** Thu thập thông tin đăng nhập của lập trình viên.

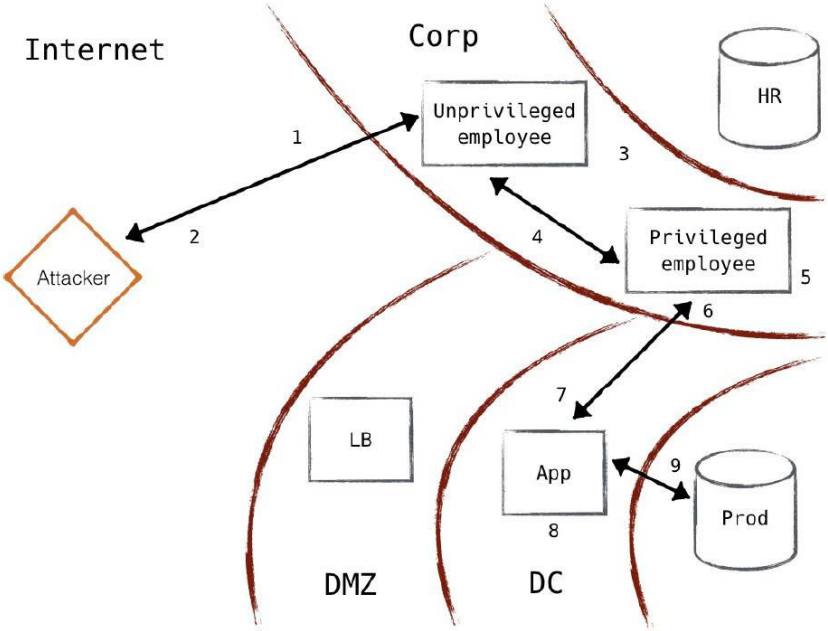


Figure 1-8. Attacker movement into corporate network, and subsequently production into network

EXAMPLE ATTACK PROGRESSION

1. Employees targeted via phishing email
2. Corporate machine compromised, shell shoveled
3. Lateral movement through corporate network
4. Privileged workstation located
5. Local privilege escalation on workstation—keylogger installed
6. Developer password stolen
7. Compromised prod app host from privileged workstation
8. Developer password used to elevate privileges on prod app host
9. Database credentials stolen from app
10. Database contents exfiltrated via compromised app host

Hình 1.5. Sơ đồ tiến trình tấn công 10 bước xâm nhập mạng doanh nghiệp và đánh cắp dữ liệu sản xuất (Example Attack Progression).

g) **Truy cập máy chủ Production:** Dùng tài khoản chiếm đoạt để kết nối vào máy chủ ứng dụng thật (*Prod App Host*).

h) **Leo quyền trên Prod Host:** Nâng đặc quyền quản trị tối cao trên máy chủ ứng dụng.

i) **Đánh cắp credential CSDL:** Trích xuất thông tin truy cập Cơ sở dữ liệu từ ứng dụng.

j) **Rút hái dữ liệu (*Exfiltration*):** Truy cập CSDL và tuồn toàn bộ dữ liệu ra ngoài Internet qua máy chủ ứng dụng bị chiếm đoạt.

1.2.4. Thiếu sót trong kiểm soát lưu lượng nội vùng và điểm lỗi đơn lẻ

Sự thất bại của bảo mật chu vi truyền thống được tổng kết qua 3 nhược điểm kiến trúc cốt lõi:

– **Thiếu khả năng kiểm tra lưu lượng nội vùng (*Lack of intra-zone traffic inspection*):** Do giả định các thiết bị trong cùng một phân vùng mạng là an toàn, lưu lượng trao đổi trực tiếp giữa các máy chủ nội bộ thường không được giám sát hoặc mã hóa chuyên sâu.

– **Thiếu tính linh hoạt trong bố trí máy chủ (*Lack of host placement flexibility*):** Cấu hình phân đoạn mạng tĩnh dựa trên địa chỉ IP gây cản trở lớn khi dịch chuyển ứng dụng sang hạ tầng Đa đám mây động.

– **Tồn tại điểm lỗi đơn lẻ (*Single Points of Failure - SPOF*) về mặt kiến trúc:** Do toàn bộ lưu lượng mạng được định tuyến tập trung qua một số ít thiết bị kiểm soát chu vi cửa ngõ (như Tường lửa trung tâm hoặc cổng VPN Gateway) để thực thi chính sách, kiến trúc này vô hình trung tạo ra nút thắt cổ chai hiệu năng. Khi các thiết bị tập trung này gặp sự cố phần cứng, lỗi cấu hình hoặc bị tấn công từ chối dịch vụ (DoS/DDoS), toàn bộ hoạt động kết nối và truy cập tài nguyên của doanh nghiệp có nguy cơ bị gián đoạn hoàn toàn.

Những hạn chế này đặt ra yêu cầu chuyển dịch sang Kiến trúc Bảo mật Zero Trust — nơi loại bỏ hoàn toàn "Sự tin cậy ngầm định" và phân tán cơ chế thực thi bảo mật ra sát biên mạng.

1.3. Triết lý Zero Trust (ZTA Philosophy)

1.3.1. Sự ra đời của khái niệm Zero Trust

Khái niệm Zero Trust được khởi xướng và giới thiệu lần đầu tiên vào năm 2010 bởi John Kindervag khi ông làm việc tại Forrester Research. Bối cảnh ra đời của mô hình xuất phát từ sự thất bại của tư duy phòng thủ truyền thống: vốn tập trung toàn bộ nguồn

lực vào việc xây dựng bức tường chu vi cứng cáp, nhưng sau khi đối tượng vượt qua rào cản cửa ngõ và vào được mạng nội bộ, họ lại được cấp quyền truy cập rộng rãi vào một tập hợp tài nguyên lớn. Hạn chế này khiến nguy cơ di chuyển sang ngang trái phép (*Lateral Movement*) trở thành một trong những thách thức an ninh mạng nghiêm trọng nhất đối với các tổ chức và doanh nghiệp.

John Kindervag nhấn mạnh rằng trong an toàn thông tin, "Sự tin cậy" (*Trust*) không phải là một thuộc tính bảo mật mà chính là một kẽ hở kiến trúc nguy hiểm. Vì vậy, Zero Trust ra đời nhằm xóa bỏ hoàn toàn khái niệm vùng tin tưởng ngầm định (*Implicit Trust Zone*) bên trong mạng nội bộ.

1.3.2. Định nghĩa nguyên tắc cốt lõi: "Never Trust, Always Verify"

Tư duy Zero Trust thay thế phương châm phòng thủ truyền thống bằng triết lý cốt lõi: ***"Never Trust, Always Verify"*** (Không bao giờ tin tưởng ngầm định, luôn luôn xác thực). Theo triết lý này:

- **Không cấp niềm tin ngầm định:** Niềm tin không bao giờ được mặc định trao cho bất kỳ người dùng, thiết bị hay tài khoản nào chỉ dựa vào vị trí vật lý hay vị trí mạng của chúng (như việc nằm trong mạng LAN hay truy cập qua VPN).
- **Đánh giá liên tục (*Continuous Evaluation*):** Mọi yêu cầu truy cập tài nguyên đều phải được xác thực, ủy quyền và đánh giá rủi ro một cách liên tục trong suốt quá trình kết nối chứ không chỉ kiểm tra một lần duy nhất tại thời điểm đăng nhập ban đầu.
- **Nguyên tắc quyền truy cập tối thiểu (*Least Privilege*):** Trọng tâm kiểm soát tập trung vào việc giới hạn tài nguyên cho những đối tượng thực sự có nhu cầu nghiệp vụ, đồng thời chỉ cấp các quyền thao tác tối thiểu (như đọc, ghi, xóa) vừa đủ để hoàn thành tác vụ.

1.3.3. Đổi mới tư duy: Chuyển từ "Bảo mật vị trí mạng" sang "Bảo mật danh tính và ứng dụng"

Mô hình Zero Trust đánh dấu một bước chuyển dịch tư duy toàn diện trong kiến trúc bảo mật doanh nghiệp hiện đại:

- **Bảo vệ toàn diện từ đầu đến cuối (*End-to-End Security*):** Zero Trust không chỉ đơn thuần là việc cài đặt một thiết bị mạng đơn lẻ, mà là một phương pháp tiếp cận toàn diện từ đầu đến cuối để bảo vệ tài nguyên và dữ liệu doanh nghiệp. Hệ thống này bao hàm và xâu chuỗi chặt chẽ các thành phần: Quản lý định danh (*Identity*), Thông tin xác thực (*Credentials*), Quản lý truy cập (*Access Management*), Thiết bị đầu cuối (*Endpoints*), Môi trường lưu trữ/máy chủ (*Hosting Environments*) và Hạ tầng kết nối (*Interconnecting Infrastructure*).

– **Dịch chuyển ranh giới bảo vệ:** Thay vì tập trung bảo vệ các phân đoạn mạng vật lý diện rộng (*Network Segments*), Zero Trust thu nhỏ ranh giới bảo mật và tập trung bảo vệ trực tiếp vào từng tài nguyên cụ thể (dữ liệu, ứng dụng, dịch vụ, thiết bị).

– **Xác thực dựa trên ngữ cảnh thực tế:** Quyết định cấp phép truy cập không dựa trên địa chỉ IP hay vị trí kết nối, mà dựa trên việc tổng hợp và phân tích ngữ cảnh thực thời (*Context-aware*): danh tính người dùng, trạng thái an toàn của thiết bị đầu cuối, ứng dụng yêu cầu và mức độ nhạy cảm của tài nguyên dữ liệu.

Chương 2.
CƠ SỞ LÝ THUYẾT VÀ CÁC MÔ HÌNH NỀN TẢNG ZERO TRUST

2.1. Khung kiến trúc tham chiếu NIST SP 800-207 và Triết lý Zero Trust

2.1.1. Khái niệm và 5 giả định kỹ thuật cốt lõi của Zero Trust

Theo đặc tả của Viện Tiêu chuẩn và Công nghệ Quốc gia Mỹ (NIST SP 800-207), Zero Trust (ZT) là bộ các khái niệm và ý tưởng nhằm tối thiểu hóa sự không chắc chắn trong việc thực thi các quyết định truy cập chính xác, cấp quyền tối thiểu (*Least Privilege*) trên từng yêu cầu truy cập trong điều kiện hệ thống mạng bị xem là đã bị xâm nhập.

Triết lý của Zero Trust dựa trên 5 giả định kỹ thuật nền tảng:

1. Mạng truyền dẫn luôn được coi là môi trường độc hại (*The network is always assumed to be hostile*).
2. Các mối đe dọa bên trong và bên ngoài luôn tồn tại trên mạng tại mọi thời điểm.
3. Vị trí kết nối mạng không đủ cơ sở để quyết định độ tin cậy.
4. Mọi thiết bị, người dùng và luồng lưu lượng đều phải được xác thực và cấp quyền.
5. Chính sách bảo mật phải mang tính động và được tính toán từ nhiều nguồn dữ liệu đa dạng.

2.1.2. 7 Nguyên tắc vàng của Kiến trúc Zero Trust (NIST SP 800-207)

Khung kiến trúc ZTA chuẩn mực bắt buộc phải tuân thủ và vận hành dựa trên 7 nguyên tắc cốt lõi:

1. Tất cả các nguồn dữ liệu và dịch vụ tính toán đều được coi là tài nguyên.
2. Mọi giao tiếp đều phải được bảo vệ bất kể vị trí mạng.
3. Cấp quyền truy cập theo từng phiên làm việc (*Per-session basis*).
4. Quyền truy cập được quyết định bởi chính sách động dựa trên thuộc tính thực thời.
5. Doanh nghiệp giám sát và đo lường liên tục tính toàn vẹn và trạng thái an toàn của mọi tài sản.

6. Mọi xác thực và ủy quyền đều mang tính động và được thực thi nghiêm ngặt.
7. Thu thập tối đa thông tin ngữ cảnh để liên tục cải thiện trạng thái bảo mật.

2.1.3. Phân tách Mặt phẳng Kiểm soát (Control Plane) và Mặt phẳng Dữ liệu (Data Plane)

Để thực hiện kiểm soát truy cập động, hệ thống thực hiện phân tách triệt để hai mặt phẳng vận hành:

– **Mặt phẳng kiểm soát (*Control Plane*):** Trung tâm ra quyết định, chịu trách nhiệm xác thực định danh, đánh giá rủi ro ngữ cảnh, tính toán điểm tin cậy và điều hướng cấu hình.

– **Mặt phẳng dữ liệu (*Data Plane*):** Nơi vận chuyển luồng dữ liệu ứng dụng thực tế. Kênh này chỉ được thiết lập sau khi Control Plane cấp phép thành công.

2.1.4. Ba thành phần logic cốt lõi và các nguồn dữ liệu phụ trợ

Kiến trúc ZTA vận hành dựa trên bộ ba thành phần logic chính:

– **Policy Engine (PE):** Động cơ quyết định chính sách, sử dụng thuật toán tin cậy (*Trust Algorithm*) để đưa ra quyết định chấp thuận hoặc từ chối truy cập.

– **Policy Administrator (PA):** Thành phần quản trị chính sách, phát tín hiệu điều khiển tới điểm thực thi để mở hoặc đóng kênh dữ liệu. Bộ đôi PE và PA hợp thành Điểm quyết định chính sách (*Policy Decision Point - PDP*).

– **Policy Enforcement Point (PEP):** Điểm thực thi chính sách nằm trên mặt phẳng dữ liệu, trực tiếp giám sát và chấm dứt kết nối theo chỉ thị từ PA.

Cơ chế PDP đưa ra quyết định chính xác nhờ tích hợp liên tục dữ liệu từ các nguồn phụ trợ: IdP/IAM, EDR/MDM, Threat Intelligence, SIEM/Activity Logs và hạ tầng PKI.

2.2. Mô hình Độ trưởng thành CISA (Zero Trust Maturity Model v2.0)

Mô hình ZTMM v2.0 của CISA định hình lộ trình chuyển đổi qua 5 trụ cột và 4 giai đoạn tiến hóa.

2.2.1. 5 Trụ cột bảo mật cốt lõi

1. **Định danh (*Identity*):** Quản lý người dùng và các đối tượng không phải con người (*NPE*). Thực thi Phishing-resistant MFA (FIDO2, PIV), hợp nhất kho định danh.

2. **Thiết bị (*Devices*):** Quản lý tài sản phần cứng và tài sản ảo, tự động hóa kiểm tra posture, triển khai giải pháp EDR.
3. **Mạng (*Networks*):** Chuyển từ bảo mật chu vi rộng sang các vùng vi chu vi (*Micro-perimeters*), phân đoạn vi mô và mã hóa toàn bộ lưu lượng.
4. **Ứng dụng và Tải công việc (*Applications & Workloads*):** Bảo mật ứng dụng trên hạ tầng on-premises và đám mây, tích hợp DevSecOps, sử dụng tải công việc bất biến.
5. **Dữ liệu (*Data*):** Tự động phân loại, gắn nhãn dữ liệu, mã hóa ở cả 3 trạng thái và triển khai hệ thống DLP.

2.2.2. Các Năng lực xuyên suốt (Cross-Cutting Capabilities)

– **Khả năng quan sát và Phân tích (*Visibility & Analytics*):** Phân tích hành vi (UEBA) và săn tìm mối đe dọa (*Threat Hunting*) dựa trên log/telemetry tập trung.

– **Tự động hóa và Điều phối (*Automation & Orchestration*):** Tự động phản ứng sự cố và thực thi chính sách đồng bộ.

– **Quản trị (*Governance*):** Định nghĩa quy trình tuân thủ an toàn thông tin và quản lý rủi ro doanh nghiệp.

2.2.3. 4 Giai đoạn phát triển độ trưởng thành

Bảng 2.1.

2.2: Bảng so sánh 4 giai đoạn tiến hóa độ trưởng thành Zero Trust theo CISA ZTMM v2.0

Giai đoạn	Đặc trưng kỹ thuật cốt lõi
Truyền thống (*Traditional*)	Cấu hình thủ công; bảo mật dựa trên chu vi tĩnh (Firewall, VPN); xác thực bằng mật khẩu/MFA tĩnh; cấp quyền cố định; quản lý tài sản và phản ứng sự cố rời rạc.
Khởi đầu (*Initial*)	Bắt đầu tự động hóa một số quy trình; áp dụng MFA kết hợp kiểm tra thuộc tính cơ bản; cô lập các tải công việc quan trọng; tập trung hóa thu thập log.
Nâng cao (*Advanced*)	Kiểm soát tự động hóa rộng rãi; áp dụng Phishing-resistant MFA (FIDO2/PIV); phân đoạn vi mô; mã hóa toàn bộ dữ liệu lưu trữ/đường truyền; ra quyết định truy cập theo thời gian thực.
Tối ưu (*Optimal*)	Tự động hóa hoàn toàn và liên tục (*Just-in-Time & Just-Enough Access*); chính sách động tự điều chỉnh bằng AI/ML; tải công việc bất biến; mã hóa dữ liệu khi đang xử lý (*In-Use*).

2.2.4. Tiêu chí đánh giá mức độ sẵn sàng chuyển đổi

Mô hình định nghĩa bộ chỉ số đánh giá hiện trạng chuyển đổi trên từng trụ cột:

– **Tiêu chí Định danh:** Tỷ lệ áp dụng FIDO2/WebAuthn, mức độ hợp nhất kho định danh và năng lực cấp quyền ABAC/JIT.

– **Tiêu chí Thiết bị:** Khả năng tự động kiểm kê 100% tài sản, tỷ lệ phủ EDR/MDM và năng lực tự động cách ly thiết bị không tuân thủ.

– **Tiêu chí Mạng:** Mức độ phân đoạn vi mô tầng ứng dụng, khả năng ẩn hệ thống (”Dark Cloud”) và tỷ lệ mã hóa TLS 1.3/mTLS.

– **Tiêu chí Ứng dụng & Tải công việc:** Tích hợp SAST/DAST vào CI/CD, loại bỏ quyền truy cập trực tiếp của admin vào Production và tỷ lệ container bất biến.

– **Tiêu chí Dữ liệu:** Tự động phân loại, gắn nhãn dữ liệu, triển khai DLP theo ngữ cảnh và mã hóa ở cả 3 trạng thái.

2.3. Các cơ chế kỹ thuật và giải pháp công nghệ nền tảng trong ZTA

Việc hiện thực hóa ZTA đòi hỏi kết hợp đồng bộ các cơ chế kỹ thuật sau:

2.3.1. Cơ chế xác thực và ủy quyền động dựa trên Network Agent và Trust Engine

Mô hình **Thực thể đại diện mạng (*Network Agent*)** hợp nhất ngữ cảnh truy cập thành một đối tượng đánh giá duy nhất.

1. **Cấu trúc của Network Agent:** Hợp nhất ba yếu tố bộ ba: Định danh người dùng (*User Identity*), Trạng thái an toàn của thiết bị (*Device Posture*) và Ứng dụng/Tải công việc khởi tạo kết nối (*Application Context*).
2. **Nguyên lý hoạt động của Động cơ tin cậy (*Trust Engine*):** Trust Engine liên tục thu thập dữ liệu từ IdP, EDR, MDM và SIEM để tính toán toán học điểm tin cậy biến đổi (*Variable Trust Score*):

$$T_{\text{score}} = f(\text{Identity_Risk}, \text{Device_Health}, \text{Network_Location}, \text{Behavioral_Anomaly}) \quad (1)$$

3. **Đánh giá và cấp quyền động:** Nếu điểm tin cậy T_{score} vượt qua ngưỡng an toàn $T_{\text{threshold}}$ do chính sách quy định đối với tài nguyên nhạy cảm R_k, PA mới phát tín hiệu xuống PEP để mở kênh kết nối tạm thời. Ngược lại, nếu trong quá trình kết nối điểm T_{score} suy giảm, kết nối sẽ lập tức bị hủy bỏ hoặc yêu cầu xác thực lại bằng Phishing-resistant MFA.

2.3.2. Cơ chế phân đoạn vi mô (Micro-segmentation) và Kỹ thuật xác thực trước gói tin (SPA)

2.3.3. Phân đoạn vi mô (*Micro-segmentation*)

Phân đoạn vi mô thu nhỏ chu vi an toàn thành các vùng vi chu vi (*Micro-perimeters*) bao quanh từng ứng dụng hoặc tải công việc (*Workload*):

– **Phân đoạn dựa trên hồ sơ ứng dụng (*Application Profiling*):** Thiết lập chính sách kiểm soát lưu lượng tầng ứng dụng (Layer 7) thay vì dựa vào IP/Subnet.

– **Kiểm soát luồng di chuyển ngang (*East-West Traffic Inspection*):** Mọi luồng giao tiếp giữa các máy chủ ứng dụng (*App Server*) và máy chủ cơ sở dữ liệu (*DB Server*) đều phải qua PEP, ngăn chặn kẻ tấn công dùng máy chủ bị chiếm quyền làm điểm nhảy (*Pivoting*).

2.3.4. Kỹ thuật xác thực trước gói tin (*Single Packet Authorization - SPA*)

SPA giải quyết bài toán ”gói tin đầu tiên” (*First Packet Problem*) bằng cơ chế ”Dark Cloud” (Ẩn hạ tầng):

1. **Khởi tạo gói tin SPA:** Thiết bị đóng gói dữ liệu xác thực mã hóa ngắn (định danh, timestamp, OTP, chữ ký số HMAC) vào duy nhất một gói tin UDP.
2. **Kiểm tra thụ động tại PEP:** PEP lắng nghe thụ động (Passive Sniffing) và không mở bất kỳ cổng TCP nào ra ngoài. Khi nhận gói tin UDP SPA, PEP giải mã và kiểm tra chữ ký HMAC.
3. **Mở cổng động (*Dynamic Pinholing*):** Nếu SPA hợp lệ, PEP thêm quy tắc tường lửa động mở cổng dịch vụ cho duy nhất địa chỉ IP người gửi trong vài giây. Mọi gói tin từ IP khác đều bị silently dropped.

2.3.5. Mã hóa toàn diện đường truyền và cơ chế mTLS / IPsec

Mọi lưu lượng dữ liệu trao đổi trong ZTA bắt buộc phải được mã hóa end-to-end:

– **Xác thực TLS hai chiều (*Mutually Authenticated TLS - mTLS*):** Triển khai ở tầng ứng dụng (Layer 7). Cả máy chủ và máy khách đều phải xuất trình chứng thư số X.509 hợp lệ do PKI cấp phát.

– **Bảo mật tầng mạng với IPsec (IKEv2):** Triển khai ở tầng mạng (Layer 3/4) cho giao tiếp máy chủ - máy chủ hoặc đám mây đa vùng, thiết lập tuyến đường hầm mã hóa bảo mật.

2.3.6. Bảo vệ dữ liệu toàn diện ở 3 trạng thái

Dữ liệu được bảo vệ xuyên suốt chu kỳ sống theo 3 trạng thái:

Bảng 2.3.

2.4: Cơ chế bảo vệ dữ liệu ở 3 trạng thái theo chuẩn ZTA

Trạng thái Dữ liệu	Biện pháp Kỹ thuật Triển khai	Công nghệ & Giao thức
Dữ liệu lưu trữ (*Data at Rest*)	Mã hóa toàn bộ ổ đĩa, cơ sở dữ liệu, bản sao lưu; quản lý khóa tập trung bằng HSM.	Thuật toán AES-256, TPM/HSM, KMS.
Dữ liệu đường truyền (*Data in Transit*)	Mã hóa bắt buộc mọi luồng lưu lượng nội bộ (East-West) và công cộng (North-South).	mTLS 1.3, IPsec (IKEv2), HTTPS (TLS 1.3).
Dữ liệu đang xử lý (*Data in Use*)	Cách ly môi trường tính toán trong bộ nhớ RAM, ngăn chặn đọc trộm dữ liệu cấp kernel.	Điện toán bảo mật (*Confidential Computing*), Hardware Enclaves (Intel SGX, AMD SEV).

2.4. So sánh Mô hình An ninh Chu vi và Kiến trúc Zero Trust

Bảng 2.6 đối chiếu chi tiết hai mô hình an ninh mạng trên các tiêu chí kiến trúc cốt lõi:

2.5. Các Thách thức Kỹ thuật và Vận hành khi Triển khai ZTA

Mặc dù mang lại hiệu quả vượt trội trong việc bảo vệ hệ thống trước các mối đe dọa hiện đại, quá trình dịch chuyển sang Kiến trúc Zero Trust đặt ra những thách thức lớn đối với doanh nghiệp:

1. **Tương thích với hệ thống cũ (*Legacy Systems*):** Các ứng dụng cổ điển (*Legacy applications*) hoặc thiết bị công nghiệp (OT/IoT) không hỗ trợ giao thức mTLS, không tích hợp được với các hệ thống IdP hiện đại (OAuth2/OIDC/SAML) hoặc không cho phép cài đặt các Agent EDR/MDM.
2. **Độ trễ và hiệu năng hệ thống (*Performance Overhead*):** Việc kiểm tra ngữ cảnh liên tục, giải mã/mã hóa dữ liệu tại các PEP và tính toán điểm tin cậy thời gian thực trên Trust Engine có thể gia tăng độ trễ kết nối (*Latency*), ảnh hưởng đến trải nghiệm người dùng nếu hạ tầng không được tối ưu hóa.

Bảng 2.5.

2.6: Bảng so sánh đối chiếu giữa Mô hình An ninh Chu vi và Kiến trúc Zero Trust

Tiêu chí Đánh giá	**Mô hình Chu vi Truyền thống (*Perimeter Model*)**	**Kiến trúc Zero Trust (*ZTA*)**
Triết lý Độ tin cậy	Tin cậy mặc định (*Implicit Trust*) dựa trên vị trí mạng nội bộ hoặc VPN.	Không tin tưởng mặc định (*Zero Implicit Trust*), ”Never Trust, Always Verify”.
Trọng tâm Bảo vệ	Bảo vệ chu vi mạng vật lý, phân vùng IP tĩnh (VLAN, Subnet).	Bảo vệ trực tiếp tài sản dữ liệu, ứng dụng, định danh và thiết bị.
Cơ chế Phân quyền	Cấp quyền tĩnh, diện rộng sau khi vượt qua tường lửa/VPN.	Cấp quyền tối thiểu (*Least Privilege*), theo từng phiên (*Per-session*) và ngữ cảnh.
Xác thực & Ủy quyền	Xác thực một lần duy nhất (*One-time Authentication*) tại thời điểm đăng nhập.	Xác thực và ủy quyền liên tục (*Continuous Evaluation*) trong suốt phiên kết nối.
Giám sát lưu lượng	Kiểm soát lưu lượng biên (North-South); bỏ qua lưu lượng nội bộ (East-West).	Phân đoạn vi mô, mã hóa và kiểm tra 100% luồng lưu lượng (North-South & East-West).
Khả năng ẩn hạ tầng	Các cổng dịch vụ hé lộ công khai trên Internet, dễ bị quét port.	Ẩn hoàn toàn tài nguyên khỏi mạng công cộng nhờ SPA/SDP (”Dark Cloud”).
Bán kính Thiệt hại (*Blast Radius*)	Rộng. Khi bị xâm nhập 1 node, kẻ tấn công dễ dàng di chuyển sang ngang.	Hẹp. Vi chu vi và cô lập tức thì giúp khoanh vùng thiết bị bị thỏa hiệp.

3. **Độ phức tạp trong quản trị chính sách (*Policy Complexity*):** Việc chuyển sang mô hình kiểm soát truy cập dựa trên thuộc tính (*ABAC*) đòi hỏi định nghĩa hàng nghìn quy tắc động. Cấu hình sai chính sách tại Động cơ chính sách (PE) có thể dẫn đến việc từ chối dịch vụ nhầm đối với người dùng hợp lệ hoặc tạo ra các kẽ hở an ninh không mong muốn.
4. **Chi phí đầu tư và thay đổi văn hóa tổ chức:** Chuyển đổi ZTA là một quá trình dài hạn, đòi hỏi ngân sách đầu tư lớn cho các giải pháp phần mềm/hạ tầng mới (FIDO2, EDR, SIEM/SOAR) và thay đổi toàn bộ thói quen làm việc của nhân viên cũng như đội ngũ vận hành CNTT.

Chương 3.
GIẢI PHÁP KỸ THUẬT ZERO TRUST NETWORK ACCESS (ZTNA)

3.1. Tổng quan về ZTNA và Khung kiến trúc SDP

3.1.1. Khái niệm ZTNA – Bản thương mại hóa của SDP

Zero Trust Network Access (ZTNA) đại diện cho bước tiến hóa trong mô hình kiểm soát truy cập từ xa. ZTNA được xem là phiên bản thương mại hóa và ứng dụng thực tiễn của kiến trúc Chu vi được định nghĩa bằng phần mềm (*Software-Defined Perimeter - SDP*).

Khác với các giải pháp mạng truyền thống cấp quyền truy cập ở cấp độ phân đoạn mạng, ZTNA tạo ra một ranh giới bảo mật logic, cô lập dựa trên định danh và ngữ cảnh thời gian thực. ZTNA thiết lập kết nối hẹp ở Tầng ứng dụng (Layer 7) trực tiếp giữa người dùng và ứng dụng cụ thể, loại bỏ hoàn toàn khả năng định tuyến tự do sang các tài nguyên khác trong hạ tầng doanh nghiệp.

3.1.2. Kiến trúc Software-Defined Perimeter (SDP) của Cloud Security Alliance

Kiến trúc SDP do tổ chức Cloud Security Alliance (CSA) chuẩn hóa được thiết kế dựa trên nguyên lý triệt hạ sự hiện diện mạng công khai (*Dark Cloud*). SDP ẩn hoàn toàn hạ tầng ứng dụng khỏi mạng Internet, biến các máy chủ ứng dụng thành vô hình đối với các công cụ dò quét rủi ro.

Mô hình SDP thực hiện phân tách triệt để giữa Mặt phẳng kiểm soát (*Control Plane*) và Mặt phẳng dữ liệu (*Data Plane*). Nhờ đó, việc xác thực định danh, đánh giá trạng thái an toàn của thiết bị và ra quyết định cấp quyền được hoàn tất hoàn toàn trên Mặt phẳng kiểm soát trước khi bất kỳ luồng lưu lượng ứng dụng nào được phép truyền tải trên Mặt phẳng dữ liệu.

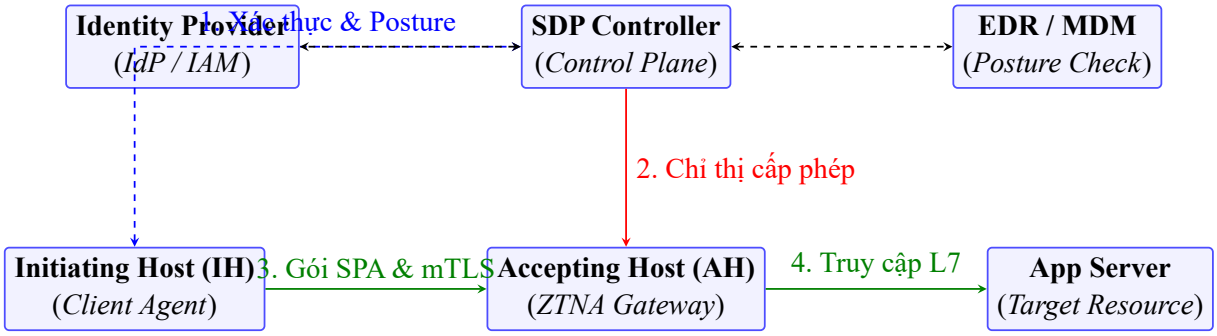
3.1.3. Các thành phần cốt lõi trong mô hình SDP

Khung kiến trúc SDP tiêu chuẩn bao gồm ba thành phần logic chính:

– **SDP Controller (Bộ điều khiển):** Đóng vai trò là trung tâm ra quyết định trên Mặt phẳng kiểm soát. Controller tiếp nhận yêu cầu kết nối, xác thực định danh người dùng qua các nhà cung cấp định danh (IdP), kiểm tra điều kiện an toàn của thiết bị và đối chiếu chính sách truy cập. Controller chỉ phát chỉ thị cho điểm chấp nhận kết nối khi yêu cầu thỏa mãn toàn bộ tiêu chí an toàn.

– **Initiating Host (IH – Thiết bị khởi tạo):** Là thành phần chạy trên thiết bị đầu cuối của người dùng (dưới dạng Agent hoặc giao diện Trình duyệt). IH chịu trách nhiệm thu thập thông tin định danh, chứng thư số, thông số cấu hình và tình trạng an toàn hệ thống để gửi tới SDP Controller nhằm xin cấp quyền kết nối.

– **Accepting Host (AH – Thiết bị chấp nhận):** Đóng vai trò là điểm thực thi chính sách trên Mặt phẳng dữ liệu, nằm ngay trước các máy chủ ứng dụng. AH liên tục lắng nghe chỉ thị từ Controller và duy trì các kết nối đi ra (*Outbound-only*). AH chỉ cho phép các gói tin mã hóa từ các IH đã qua xác thực truyền qua để truy cập ứng dụng đích.



3.2: Mô hình Kiến trúc SDP phân tách Mặt phẳng Kiểm soát và Mặt phẳng Dữ liệu

Hình 3.2.

3.2. Các cơ chế kỹ thuật nòng cốt của ZTNA

3.2.1. Cơ chế ”Dark Cloud” (Mạng ẩn) và nguyên lý Default Deny

Cơ chế ”Dark Cloud” áp dụng triết lý từ chối mặc định (*Default Deny*). Trong mô hình này, các cổng dịch vụ đi vào (*Inbound Ports*) trên hệ thống tường lửa biên và gateway đều được đóng hoàn toàn đối với lưu lượng truy cập công cộng.

Hạ tầng ứng dụng không phản hồi các gói tin thăm dò ICMP hoặc TCP SYN từ bên ngoài, khiến toàn bộ hệ thống hoàn toàn ẩn khỏi các công cụ rà quét cổng (*Port Scanning*) và công cụ tìm kiếm lỗ hổng tự động. Bề mặt tấn công của doanh nghiệp được thu nhỏ về mức tối thiểu, ngăn ngừa các cuộc tấn công thăm dò và khai thác lỗ hổng Zero-day.

3.2.2. Xác thực trước gói tin (Single Packet Authorization – SPA)

Xác thực trước gói tin (SPA) là kỹ thuật mật mã hóa cho phép thiết bị khởi tạo (IH) chứng minh quyền truy cập hợp lệ tới thiết bị chấp nhận (AH) chỉ bằng một gói tin mã hóa duy nhất trước khi bất kỳ kết nối TCP/UDP nào được khởi tạo.

1. **Khởi tạo và Mã hóa:** Khi người dùng yêu cầu truy cập, Client Agent đóng gói dữ liệu bao gồm: định danh người dùng, dấu thời gian (*Timestamp*), địa chỉ IP nguồn và khóa OTP hoặc chữ ký số HMAC vào một gói tin UDP duy nhất.
2. **Kiểm tra thụ động:** AH vận hành ở chế độ lắng nghe thụ động (*Passive Sniffing*) tại tầng liên kết dữ liệu mà không mở cổng lắng nghe giao thức TCP.
3. **Mở cổng động (*Dynamic Pinholing*):** AH giải mã gói tin SPA và xác thực chữ ký số. Nếu gói tin hợp lệ, AH cập nhật tạm thời quy tắc tường lửa trong vài giây, cho phép duy nhất địa chỉ IP nguồn của Client thiết lập bắt tay TCP tới cổng ứng dụng. Mọi gói tin không chứa SPA hợp lệ đều bị silently dropped.

3.2.3. Xác thực TLS hai chiều (Mutual TLS – mTLS)

Khi cổng kết nối tạm thời được mở thông qua SPA, ZTNA thực thi cơ chế xác thực TLS hai chiều (mTLS) ở Tầng ứng dụng nhằm đảm bảo tính bảo mật và toàn vẹn của đường truyền:

– **Xác thực hai chiều:** Khác với giao thức TLS thông thường (chỉ máy chủ xuất trình chứng thư), mTLS bắt buộc cả Client và ZTNA Gateway phải xuất trình chứng thư số X.509 hợp lệ do Hạ tầng khóa công khai (*PKI*) của doanh nghiệp cấp phát.

– **Mã hóa End-to-End:** Kênh truyền mã hóa mTLS ngăn chặn triệt để các cuộc tấn công nghe lén, giả mạo thiết bị và tấn công đứng giữa (*Man-in-the-Middle*).

3.2.4. Động cơ đánh giá tin cậy động (Trust Engine) và Kiểm soát truy cập ABAC

Động cơ đánh giá tin cậy động (*Continuous Adaptive Trust Engine*) đóng vai trò là bộ não phân tích rủi ro của ZTNA Controller:

– **Mô hình kiểm soát ABAC (*Attribute-Based Access Control*):** Thay vì phân quyền tĩnh theo vai trò (RBAC), ZTNA áp dụng mô hình ABAC đánh giá linh hoạt dựa trên tổ hợp thuộc tính: Thuộc tính định danh, Thuộc tính thiết bị, Thuộc tính môi trường mạng và Thuộc tính tài nguyên.

– **Thuật toán tính toán điểm tin cậy thời gian thực:** Trust Engine liên tục tính toán điểm số tin cậy T_{score} biến đổi dựa trên dữ liệu tổng hợp từ IdP, EDR, MDM và SIEM. Nếu điểm T_{score} giảm xuống dưới ngưỡng an toàn quy định cho ứng dụng

nhạy cảm R_k, hệ thống sẽ ngay lập tức yêu cầu xác thực bổ sung (MFA) hoặc hạ cấp quyền truy cập.

3.3. Phân loại các mô hình kiến trúc ZTNA

3.3.1. Client-initiated ZTNA (Dựa trên Agent) và Quy trình kiểm tra Device Posture

Mô hình này yêu cầu cài đặt ứng dụng Agent chuyên dụng trên thiết bị đầu cuối của người dùng.

- **Nguyên lý hoạt động và Thu thập Device Posture:** Agent chạy ngầm trên thiết bị, liên tục thu thập các thông số kỹ thuật về tình trạng an toàn của hệ thống (*Device Posture*) bao gồm: phiên bản hệ điều hành, trạng thái cập nhật bản vá, tình trạng mã hóa ổ đĩa (BitLocker/FileVault) và chỉ số từ phần mềm EDR/Antivirus. Các dữ liệu này được đính kèm vào yêu cầu xác thực gửi tới Controller.
- **Ưu điểm:** Hỗ trợ toàn diện mọi giao thức mạng (HTTP/HTTPS, SSH, RDP, SMB, UDP/TCP tùy biến); có khả năng đánh giá sâu và liên tục tình trạng an toàn thiết bị đầu cuối.
- **Nhược điểm:** Tăng độ phức tạp trong công tác quản trị và triển khai Agent trên diện rộng; không phù hợp áp dụng cho thiết bị cá nhân của nhân viên (BYOD) hoặc lực lượng lao động tạm thời/nhà thầu.
- **Trường hợp áp dụng:** Lực lượng nhân viên chính thức sử dụng máy tính do công ty cấp (*Corporate-managed Devices*) cần truy cập vào các ứng dụng nội bộ đa giao thức.

3.3.2. Service-initiated ZTNA (Agentless / Reverse Proxy)

Mô hình Agentless sử dụng công nghệ Máy chủ ủy nhiệm ngược (*Reverse Proxy / Identity-Aware Proxy*) kết hợp với các trình duyệt web tiêu chuẩn.

- **Nguyên lý kết nối Outbound-only:** Một ZTNA Connector/Broker đặt tại trung tâm dữ liệu nội bộ sẽ chủ động mở và duy trì kênh kết nối đi ra (*Outbound Connection*) tới ZTNA Cloud Service. Khi người dùng truy cập vào ứng dụng qua cổng Web, ZTNA Cloud Service xác thực định danh qua SSO/IdP và bắc cầu luồng dữ liệu về Connector nội bộ mà không cần mở cổng vào trên tường lửa doanh nghiệp.
- **Ưu điểm:** Triển khai tức thì, không yêu cầu cài đặt bất kỳ phần mềm nào trên máy trạm; tương thích hoàn hảo với các mô hình thiết bị cá nhân (BYOD) và đối tác bên ngoài.

– **Nhược điểm:** Bị giới hạn bởi các giao thức hỗ trợ trên trình duyệt web (chủ yếu là HTTP/HTTPS, SSH/RDP qua HTML5 terminal); khả năng kiểm tra tình trạng an toàn thiết bị bị hạn chế.

– **Trường hợp áp dụng:** Cấp quyền truy cập cho nhà thầu bên thứ ba, tư vấn viên hoặc nhân viên sử dụng thiết bị cá nhân (BYOD) truy cập vào các ứng dụng chuẩn Web.

3.3.3. Các mô hình phân bổ hạ tầng (Cloud-Managed Broker vs. On-Premises Gateway)

Giải pháp ZTNA có thể được phân bổ linh hoạt theo ba dạng kiến trúc triển khai thực tế:

– **Mô hình Đám mây thuần túy (Cloud-Managed Broker / SaaS ZTNA):** Controller và Gateway nằm hoàn toàn trên hạ tầng Đám mây toàn cầu của nhà cung cấp giải pháp. Mô hình này tối ưu hóa định tuyến lưu lượng trực tiếp (*Direct-to-App*), giảm thiểu độ trễ cho người dùng toàn cầu.

– **Mô hình Cục bộ (On-Premises / Private ZTNA):** Controller và Gateway được cài đặt hoàn toàn trong Trung tâm dữ liệu nội bộ của doanh nghiệp. Mô hình này phù hợp với các tổ chức có yêu cầu nghiêm ngặt về chủ quyền dữ liệu như Ngân hàng, Tài chính, Quốc phòng và Cơ quan Nhà nước.

– **Mô hình Lai (Hybrid ZTNA):** Mặt phẳng kiểm soát (Controller) được quản lý tập trung trên Đám mây, trong khi Mặt phẳng dữ liệu (Gateway/Connector) được phân bổ linh hoạt tại cả Trung tâm dữ liệu nội bộ và các nền tảng Đa đám mây.

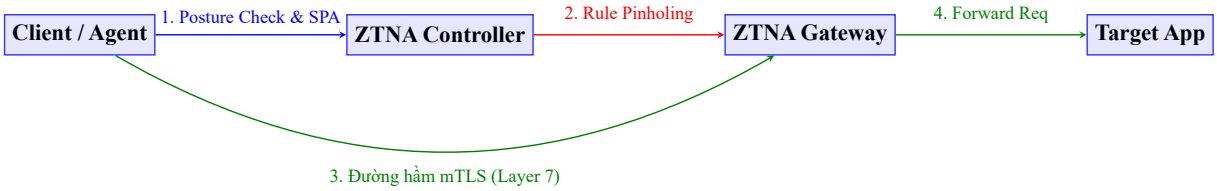
3.4. Phân tích chi tiết Luồng dữ liệu (Data Flow) trong ZTNA

3.4.1. Quy trình 4 bước khởi tạo và bắc cầu kết nối Tầng 7

Quy trình xử lý luồng dữ liệu từ khi người dùng khởi tạo yêu cầu đến khi thiết lập kênh truyền thông an toàn trong ZTNA trải qua 4 bước nối tiếp:

1. **Bước 1: Khởi tạo yêu cầu và Kiểm tra trạng thái thiết bị (Device Posture Check):** Người dùng khởi tạo yêu cầu truy cập tới một ứng dụng doanh nghiệp. ZTNA Agent trên máy trạm chặn yêu cầu này, thực hiện thu thập dữ liệu về tình trạng an toàn của thiết bị (mã hóa ổ đĩa, trạng thái EDR, phiên bản OS) và tổng hợp thành tệp dữ liệu ngữ cảnh.

2. **Bước 2: Gửi gói SPA và Xác thực định danh tại ZTNA Controller:** Agent đóng gói thông tin ngữ cảnh và gửi gói tin SPA mã hóa tới ZTNA Controller trên Mặt phẳng kiểm soát. Controller tiến hành xác thực định danh người dùng thông qua hệ thống IdP (thực thi MFA chống lừa đảo), đồng thời đánh giá tình trạng an toàn thiết bị. Nếu đạt yêu cầu chính sách, Controller phát một mã ủy quyền có thời hạn ngắn (*Short-lived Session Token*).
3. **Bước 3: Điều khiển thực thi và Cấu hình ZTNA Gateway:** ZTNA Controller gửi chỉ thị điều khiển tới ZTNA Gateway nằm ở Mặt phẳng dữ liệu. Gateway dựa trên chỉ thị này để cấu hình quy tắc tường lửa động (*Dynamic Pinholing*), chỉ mở cổng cho đúng IP nguồn của phiên trong thời gian ngắn.
4. **Bước 4: Thiết lập kênh kết nối bắc cầu Tầng 7 (Application Bridging):** ZTNA Gateway thiết lập đường truyền mã hóa mTLS với Client Agent, đồng thời ghép nối với kết nối Outbound duy trì sẵn từ ZTNA Connector nội bộ. Kết nối bắc cầu ở Tầng ứng dụng (Layer 7) được hoàn tất, cho phép người dùng trao đổi dữ liệu an toàn với duy nhất ứng dụng đích được chỉ định.



3.4: Sơ đồ Chuỗi Tiến trình Luồng dữ liệu 4 bước trong Kết nối ZTNA

Hình 3.4.

3.4.2. Cơ chế giám sát liên tục và thu hồi phiên tức thì (Continuous Enforcement)

Không giống như các giải pháp truyền thống chỉ kiểm tra một lần tại thời điểm đăng nhập, ZTNA duy trì cơ chế đánh giá liên tục trong suốt chu kỳ sống của phiên kết nối:

- **Thu thập Telemetry thực thời:** ZTNA Controller liên tục nhận các luồng dữ liệu giám sát từ Agent và hệ thống EDR/SIEM.
- **Kích hoạt công tắc ngắt khẩn cấp (Kill-Switch):** Nếu thiết bị đầu cuối phát sinh dấu hiệu bất thường (ví dụ: EDR phát hiện mã độc thực thi, người dùng thay đổi IP/vị trí địa lý đột ngột, hoặc chứng thư bị thu hồi), Controller lập tức phát lệnh thu hồi *Session Token* xuống ZTNA Gateway.
- **Đóng ngắt phiên tức thì:** ZTNA Gateway hủy bỏ đường hầm mã hóa mTLS/Reverse Tunnel ngay tại thời điểm thực thời, cô lập thiết bị khỏi ứng dụng mà không ảnh hưởng đến các phiên kết nối khác trong hệ thống.

Chương 4.
SO SÁNH CHUYÊN SÂU ZTNA VÀ CÁC GIẢI PHÁP TRUYỀN THỐNG

4.1. So sánh về Kiến trúc và Tầng hoạt động (Layer 3/4 vs Layer 7)

4.1.1. Cơ chế cấp quyền ở Tầng Mạng/Giao vận (Layer 3/4) trong VPN truyền thống

Giải pháp Mạng riêng ảo (VPN) được thiết kế dựa trên triết lý bảo mật chu vi cổ điển, dựa vào ranh giới địa lý hoặc phân đoạn IP để xác định độ tin cậy. Khi người dùng thiết lập kết nối VPN thành công (thông qua giao thức IPsec hoặc SSL/TLS VPN), hệ thống khởi tạo một giao diện mạng ảo (*Virtual Network Interface - TUN/TAP*) trên thiết bị đầu cuối và cấp cho thiết bị một địa chỉ IP nội bộ thuộc dải Subnet của doanh nghiệp.

Về bản chất, VPN hoạt động ở Tầng Mạng (*Layer 3*) hoặc Tầng Giao vận (*Layer 4*) trong mô hình OSI:

– **Cấu trúc Giao hầm IPsec/SSL (IP Tunneling Mechanics):** VPN thực hiện đóng gói toàn bộ gói tin IP (*IP-in-IP Encapsulation*). Gói tin IP gốc từ thiết bị người dùng (chứa IP nguồn nội bộ và IP đích nội bộ) được mã hóa và bọc bên trong một tiêu đề IP công cộng (*Outer IP Header*) để truyền qua Internet. Khi tới VPN Concentrator tại trung tâm dữ liệu, tiêu đề ngoài bị bóc tách và gói tin IP gốc được đẩy thẳng vào mạng LAN.

– **Khả năng định tuyến toàn phân đoạn (Subnet Routing):** Ngay khi giao hầm kết nối được thiết lập, phần mềm VPN Client sẽ can thiệp vào bảng định tuyến (*Routing Table*) của hệ điều hành, thêm các tuyến đường (*Routes*) hướng toàn bộ luồng dữ liệu về giao diện TUN/TAP. Thiết bị người dùng trở thành một nút mạng (*Node*) chính thức trong dải Subnet nội bộ, có khả năng phát các gói tin ARP, ICMP, và truyền thông điệp IP tự do tới các địa chỉ lân cận.

– **Cấp quyền theo dải IP và Cổng (IP/Port-based ACLs):** Việc kiểm soát truy cập trên VPN phụ thuộc hoàn toàn vào quy tắc Tường lửa (*Firewall Access Control Lists*) dựa trên bộ 5 tham số (*5-tuple*): địa chỉ IP nguồn, địa chỉ IP đích, cổng nguồn, cổng đích và giao thức. Mô hình này hoàn toàn ”mù” về mặt ngữ cảnh ứng dụng (*Application-unaware*). Nếu mở quyền IP cho một máy chủ, người dùng có thể tiếp

cận mọi dịch vụ chạy trên máy chủ đó (HTTP cổng 80, SSH cổng 22, RDP cổng 3389, SMB cổng 445).

4.1.2. Cơ chế cấp quyền ở Tầng Ứng dụng (Layer 7) trong ZTNA

Khác biệt hoàn toàn với VPN, ZTNA dịch chuyển điểm kiểm soát lên Tầng Ứng dụng (*Layer 7*). ZTNA loại bỏ khái niệm "đưa thiết bị vào mạng nội bộ" và thay thế bằng cơ chế bắc cầu ứng dụng có điều kiện (*Application Bridging*).

- **Cô lập hoàn toàn với Tầng Mạng (L3 Network Isolation):** Trong mô hình ZTNA, thiết bị đầu cuối không bao giờ được cấp địa chỉ IP nội bộ và không nhận bất kỳ tuyến định tuyến IP nào vào hạ tầng doanh nghiệp. Bảng định tuyến của hệ điều hành không bị thay đổi. Thiết bị bị cô lập hoàn toàn khỏi giao thức ARP, ICMP, và các lưu lượng Quảng bá/Đa hướng (*Broadcast/Multicast*) của mạng LAN.
- **Chu vi vi mô từng ứng dụng (Per-Application Micro-Perimeter):** ZTNA thiết lập một kênh giao tiếp điểm-nối-điểm (*Point-to-Point*) được mã hóa hẹp, chỉ gắn liền với duy nhất tiến trình (*Process*) hoặc ứng dụng được chỉ định. ZTNA Gateway chỉ chuyển tiếp duy nhất các luồng dữ liệu HTTP/HTTPS hoặc SSH/RDP dành riêng cho Tên miền dịch vụ (*Fully Qualified Domain Name - FQDN*) đã được phê duyệt.
- **Cơ chế Ủy nhiệm nhận biết Định danh (Identity-Aware L7 Proxying):** ZTNA Connector đóng vai trò là một L7 Reverse Proxy. Connector chấm dứt phiên TCP/TLS từ phía Client, bóc tách tiêu đề L7 để kiểm tra và xác thực từng yêu cầu HTTP/giao thức, đối chiếu mã thông báo ủy quyền (*Session Token*) trước khi tạo một kết nối nội bộ mới tới máy chủ ứng dụng.

4.1.3. Phân tích So sánh giữa Mô hình Định tuyến và Mô hình Ủy nhiệm L7

Sự khác biệt về tầng hoạt động dẫn đến hai triết lý kiểm soát truy cập đối lập:

- **Mô hình Định tuyến (Routing Model - VPN):** Dựa trên việc chuyển tiếp gói tin (*Packet Forwarding*). Tường lửa và VPN Concentrator đóng vai trò là các bộ định tuyến L3/L4. Một khi gói tin vượt qua khâu kiểm tra ACL ban đầu, nó được tự do di chuyển qua các hạ tầng mạng trung gian để tới đích mà không chịu sự kiểm tra nội dung L7 liên tục.
- **Mô hình Ủy nhiệm (Proxy/Broker Model - ZTNA):** Dựa trên việc ngắt đoạn và thiết lập lại kết nối (*Connection Termination & Re-origination*). ZTNA Gateway chấm dứt phiên kết nối TCP/TLS từ Client, kiểm tra tính hợp lệ của ngữ cảnh L7, và sau đó khởi tạo một phiên kết nối nội bộ hoàn toàn mới từ ZTNA Connector tới

máy chủ ứng dụng. Hai không gian mạng (Client-side và Server-side) được tách biệt hoàn toàn về mặt logic lẫn vật lý.

Sự khác biệt cốt lõi giữa hai mô hình chính là: VPN mở rộng chu vi mạng đến thiết bị người dùng, còn ZTNA thu hẹp chu vi bảo mật về đúng ứng dụng đích.

4.2. So sánh Bề mặt tấn công, Mô hình đe dọa và An toàn thông tin

4.2.1. Phân tích Di chuyển ngang (Lateral Movement) theo Chuỗi tấn công MITRE ATT&CK

Nguy cơ di chuyển ngang là điểm yếu nguy hiểm nhất của kiến trúc VPN truyền thống khi đối mặt với các cuộc tấn công APT hoặc mã độc tống tiền (Ransomware):

– **Chuỗi xâm nhập qua VPN (VPN Kill Chain):**

1. *Thâm nhập ban đầu (Initial Access):* Kẻ tấn công chiếm tài khoản VPN qua Phishing, Credential Stuffing hoặc khai thác lỗ hổng thiết bị VPN.
2. *Thăm dò nội bộ (Discovery - T1046):* Khi kết nối VPN được lập, kẻ tấn công thực hiện quét dải Subnet nội bộ (‘nmap -sP 192.168.1.0/24‘), phát hiện các máy chủ active, các cổng dịch vụ mở và các dịch vụ Active Directory/Domain Controller.
3. *Di chuyển sang ngang (Lateral Movement - T1210):* Kẻ tấn công lợi dụng các giao thức quản trị như SMB (Port 445), RDP (Port 3389), WMI hoặc SSH để lây nhiễm chéo sang các máy chủ lân cận, khai thác lỗ hổng như EternalBlue hay ZeroLogon.

– **Khả năng triệt tiêu di chuyển ngang của ZTNA:** Do ZTNA không cấp kết nối ở tầng IP, thiết bị của người dùng hoàn toàn không thể ”nhìn thấy” hoặc giao tiếp với các thiết bị khác trong cùng Trung tâm dữ liệu. Lệnh ‘ping‘, ‘traceroute‘, hay quét dải IP nội bộ đều thất bại do không có tuyến định tuyến L3. Bán kính thiệt hại (*Blast Radius*) được giới hạn tuyệt đối trong duy nhất ứng dụng được phân quyền.

4.2.2. Khả năng triệt tiêu tấn công Quét cổng (Port Scanning) và Thăm dò lỗ hổng

– **Bề mặt hiển thị của VPN:** VPN Concentrator bắt buộc phải mở các cổng kết nối công khai ra Internet (cổng 443 cho SSL-VPN, cổng 500/4500 cho IPsec). Các cổng này liên tục bị quét bởi các cỗ máy như Shodan, Censys. Khi xuất hiện lỗ hổng Zero-day trên thiết bị VPN (như các lỗ hổng RCE nổi tiếng trên Fortinet, Pulse Secure,

Palo Alto), kẻ tấn công có thể khai thác trực tiếp từ Internet mà không cần qua bước xác thực ban đầu.

– **Cơ chế Mạng ẩn (Dark Cloud) trong ZTNA:** ZTNA áp dụng triết lý đóng toàn bộ cổng đi vào (*Zero Inbound Open Ports*). Các máy chủ ứng dụng và ZTNA Connector nằm hoàn toàn đằng sau tường lửa ở chế độ 'Default Deny'. ZTNA Connector chỉ chủ động mở các kết nối đi ra (*Outbound-only connections*) tới ZTNA Cloud Broker. Khi kẻ tấn công thực hiện quét TCP SYN hoặc ICMP ping tới IP công cộng của doanh nghiệp, hệ thống hoàn toàn ngắt kết nối và không phản hồi, khiến hạ tầng trở nên "vô hình".

4.2.3. Phòng chống tấn công Từ chối dịch vụ (DDoS) và Tấn công đứng giữa (MitM)

– **Phòng chống tấn công DDoS:** Hạ tầng VPN tập trung tại Trung tâm dữ liệu chính (HQ) dễ dàng trở thành mục tiêu của các cuộc tấn công DDoS làm cạn kiệt băng thông hoặc tài nguyên xử lý (SYN Flood, SSL Handshake Flood). Trái lại, ZTNA tận dụng hạ tầng Đám mây phân tán toàn cầu (Cloud Edge Network). Lưu lượng tấn công DDoS bị hấp thụ và triệt tiêu ngay tại các nút Edge gần nguồn phát nhất trước khi chạm tới hạ tầng doanh nghiệp.

– **Phòng chống tấn công Man-in-the-Middle (MitM):** VPN truyền thống thường khó kiểm soát triệt để tính hợp lệ của chứng thư trên máy trạm. ZTNA bắt buộc áp dụng giao thức mTLS (Mutual TLS), trong đó cả Client và Gateway đều phải xác minh chứng thư X.509 hai chiều ở cấp độ mã hóa phần cứng (TPM/Secure Enclave), vô hiệu hóa hoàn toàn nguy cơ giả mạo Gateway hoặc nghe lén.

4.3. So sánh Hiệu năng, Trải nghiệm và Quản trị Vận hành

4.3.1. Mô hình hóa Toán học Độ trễ và Hiện tượng Nghẽn cổ chai (Hairpinning)

Trong bối cảnh doanh nghiệp chuyển dịch sang sử dụng các ứng dụng Điện toán đám mây (SaaS như Microsoft 365, Salesforce), kiến trúc VPN bộc lộ suy giảm hiệu năng nghiêm trọng do hiện tượng "Vòng ngược luồng dữ liệu" (*Traffic Hairpinning / Backhauling*).

– **Mô hình độ trễ trong VPN ($T_{\mathbf{VPN}}$):** Khi người dùng truy cập ứng dụng SaaS qua VPN, lưu lượng bị đóng hầm kéo về Trung tâm dữ liệu chính (HQ) để kiểm tra qua Tường lửa NGFW rồi mới đẩy ra Internet. Tổng độ trễ truyền tải được tính bằng

công thức:

$$T_{\text{VPN}} = T_{\text{Client}\to\text{HQ}} + T_{\text{Inspection}} + T_{\text{HQ}\to\text{SaaS}} + T_{\text{SaaS}\to\text{HQ}} + T_{\text{HQ}\to\text{Client}} \quad (2)$$

Đường đi vòng này làm tăng gấp đôi quãng đường truyền dẫn mạng, làm tăng biến động độ trễ (*Jitter*) và gây tắc nghẽn băng thông WAN tại HQ.

– **Mô hình độ trễ trong ZTNA (T_{ZTNA}):** ZTNA ứng dụng cơ chế Định tuyến trực tiếp tối ưu (*Direct-to-App Routing*). Client kết nối tới Nút Edge Cloud gần nhất qua IP Anycast:

$$T_{\text{ZTNA}} = T_{\text{Client}\to\text{Edge}} + T_{\text{Edge_Inspection}} + T_{\text{Edge}\to\text{SaaS}} \quad (3)$$

Do $T_{\text{Client}\to\text{Edge}} \ll T_{\text{Client}\to\text{HQ}}$, tổng thời gian đáp ứng của ZTNA giảm từ 40% đến 60% so với VPN, tối ưu hóa cho các dịch vụ thời gian thực như VoIP và Video Conferencing.

4.3.2. Định tuyến luồng dữ liệu tối ưu qua Cloud Edge

ZTNA phân tách rõ ràng luồng lưu lượng thông qua kỹ thuật Phân luồng thông minh (*Native Split-Tunneling*):

– **Lưu lượng Internet/SaaS công cộng:** Đẩy trực tiếp từ máy trạm ra Internet dưới sự kiểm soát chính sách của SWG/CASB tại Cloud Edge.

– **Lưu lượng Ứng dụng Nội bộ:** Được mã hóa và định tuyến qua đường hầm ZTNA Connector về Trung tâm dữ liệu. Phương pháp này giải phóng hoàn toàn băng thông cho mạng WAN doanh nghiệp.

4.3.3. Độ phức tạp Quản trị Chính sách, Khả năng mở rộng và Chi phí (CAPEX/OPEX)

– **Độ phức tạp chính sách ($O(N)$ vs $O(N \times M)$):** Trong hệ thống VPN, việc duy trì chính sách dựa trên IP/Subnet dẫn đến sự bùng nổ số lượng quy tắc tường lửa ($O(N \times M)$ với N người dùng và M phân đoạn mạng). Đối với ZTNA, chính sách dựa trên thuộc tính ABAC gắn liền với định danh tập trung, giúp giảm độ phức tạp quản trị về mức $O(N + M)$.

– **Khả năng mở rộng và Chi phí:** Mở rộng VPN đòi hỏi mua thêm thiết bị phần cứng VPN Concentrator đắt đỏ (chi phí CAPEX) và nâng cấp băng thông Leased-line. ZTNA chuyển đổi toàn bộ sang mô hình Đám mây (*Cloud-native*), hỗ trợ tự động mở rộng quy mô (*Auto-scaling*) theo nhu cầu thực tế (chuyển dịch sang chi phí vận hành OPEX).

4.3.4. Bảng tổng hợp so sánh tiêu chí kỹ thuật toàn diện

Bảng 4.2 đối chiếu tổng thể các tiêu chí kỹ thuật cốt lõi giữa VPN truyền thống và ZTNA:

Bảng 4.1.

4.2: Bảng đối chiếu tiêu chí kỹ thuật giữa VPN truyền thống và giải pháp ZTNA

Tiêu chí So sánh	**Mạng riêng ảo (VPN Truyền thống)**	**Giải pháp ZTNA (Zero Trust)**
Tầng hoạt động OSI	Tầng Mạng / Giao vận (Layer 3 / Layer 4).	Tầng Ứng dụng (Layer 7).
Mô hình kết nối	Định tuyến tập trung về HQ (*Hub-and-Spoke*).	Ủy nhiệm ứng dụng L7 (*Application Proxy*).
Phạm vi cấp quyền	Cấp quyền theo dải IP / Subnet mạng nội bộ.	Cấp quyền đích danh từng ứng dụng (*Per-App*).
Trạng thái cổng kết nối	Mở cổng Inbound công khai (443/500/4500).	Đóng toàn bộ cổng vào (*Outbound-only*).
Bề mặt hiển thị	Lộ diện IP và Cổng dịch vụ ra Internet.	Mạng ẩn hoàn toàn (*Dark Cloud*).
Di chuyển ngang	Rất cao. Nguy cơ lây nhiễm toàn bộ LAN.	Bằng không. Người dùng bị cô lập L3.
Xác thực thiết bị	Kiểm tra một lần khi khởi tạo phiên kết nối.	Đánh giá tin cậy liên tục (*Continuous Verification*).
Mô hình Định tuyến	Kéo lưu lượng về HQ (*Traffic Hairpinning*).	Định tuyến trực tiếp tới Edge (*Direct-to-App*).
Độ phức tạp Chính sách	Cao ($O(N \times M)$ quy tắc Tường lửa tĩnh).	Thấp ($O(N + M)$ quy tắc ABAC định danh).
Khả năng mở rộng	Bị giới hạn bởi phần cứng thiết bị (CAPEX).	Mở rộng linh hoạt trên Đám mây (OPEX).

4.4. Đánh giá Tổng quan và Định hướng Áp dụng

4.4.1. Tổng hợp các Đánh giá Cốt lõi giữa VPN và ZTNA

Qua phân tích đối chiếu chuyên sâu về kiến trúc, bề mặt tấn công và hiệu năng vận hành, có thể rút ra các đánh giá tổng quan mang tính bản chất như sau:

1. **Tính tất yếu của sự chuyển dịch:** Sự sụp đổ của ranh giới mạng vật lý cổ điển khiến triết lý ”Tin tưởng nhưng Kiểm tra” trên VPN không còn đáp ứng được yêu cầu bảo mật trong môi trường Đa đám mây và Làm việc linh hoạt. ZTNA là câu trả lời kỹ thuật chuẩn hóa dựa trên triết lý ”Không tin tưởng bất kỳ ai, Luôn luôn xác thực”.

2. **Ưu thế vượt trội về An toàn thông tin:** Bằng cách dịch chuyển điểm kiểm soát lên Tầng Ứng dụng (L7) và áp dụng cơ chế Mạng ẩn (*Dark Cloud*), ZTNA triệt tiêu hai nguy cơ bảo mật lớn nhất của VPN là **Di chuyển sang ngang (*Lateral Movement*)** khi bị chiếm quyền điều khiển và **Thăm dò khai thác lỗ hổng Zero-day** trên các cổng Inbound mở công khai.
3. **Cải thiện Hiệu năng và Trải nghiệm Người dùng:** ZTNA loại bỏ điểm nghẽn "Vòng ngược luồng dữ liệu" (*Hairpinning*) của VPN, cho phép định tuyến trực tiếp từ máy trạm tới Nút Edge gần nhất, giúp giảm đáng kể độ trễ truyền tải cho các ứng dụng thời gian thực và SaaS.

4.4.2. Những Thách thức và Định hướng Chuyển đổi Thực tế

Dù mang lại nhiều ưu điểm vượt trội, việc thay thế hoàn toàn hệ thống VPN bằng ZTNA trong thực tế doanh nghiệp vẫn đòi hỏi lộ trình cân nhắc toàn diện:

- **Bài toán Tương thích Ứng dụng Cũ (Legacy Apps):** Mô hình Service-initiated (Clientless ZTNA) bị giới hạn bởi các giao thức chuẩn Web. Đối với các ứng dụng cũ sử dụng giao thức Proprietary TCP/UDP hoặc yêu cầu kết nối L3 trực tiếp, doanh nghiệp bắt buộc phải áp dụng mô hình Client-initiated (Agent-based ZTNA) hoặc duy trì giải pháp song song trong giai đoạn chuyển tiếp.
- **Phụ thuộc vào Hạ tầng Định danh (IAM):** ZTNA lấy định danh làm trung tâm. Việc triển khai ZTNA chỉ thực sự hiệu quả khi doanh nghiệp đã chuẩn hóa kho định danh tập trung (Active Directory/LDAP), hỗ trợ SSO và thực thi MFA chống lừa đảo.
- **Định hướng Lộ trình Chuyển đổi:** Doanh nghiệp nên tiếp cận theo mô hình cuốn chiếu: Bắt đầu từ việc cấp quyền cho các bên thứ ba/nhà thầu thông qua Clientless ZTNA, sau đó áp dụng Agent-based ZTNA cho lực lượng nhân viên làm việc từ xa, và tiến tới ngưng vận hoàn toàn hệ thống VPN truyền thống.

Chương 5.
TRIỂN KHAI THỰC TẾ, THÁCH THỨC VÀ XU HƯỚNG TƯƠNG LAI

5.1. Kịch bản ứng dụng và Nghiên cứu tình huống thực tế (Case Studies)

5.1.1. Lực lượng lao động từ xa và làm việc kết hợp: Case Study Google BeyondCorp

Trong môi trường làm việc kết hợp (*Hybrid Work*), nhân viên thường xuyên truy cập tài nguyên nội bộ từ mạng gia đình hoặc mạng công cộng không đáng tin cậy. Điển hình thực tế rõ nét nhất cho kịch bản này là dự án **BeyondCorp** do Google triển khai từ năm 2011 đến năm 2017 [**?**].

– **Bối cảnh và vấn đề gặp phải:** Sau chiến dịch tấn công có chủ đích *Operation Aurora* (cuối năm 2009) nhắm vào hạ tầng mạng doanh nghiệp, Google nhận thấy mô hình bảo mật chu vi dựa trên tường lửa biên và VPN truyền thống tồn tại điểm yếu chí mạng: một khi thiết bị vượt qua cổng VPN, hệ thống mặc định tin cậy toàn bộ lưu lượng xuất phát từ dải IP nội bộ, tạo điều kiện cho kẻ tấn công di chuyển sang ngang. Bên cạnh đó, việc duy trì kết nối VPN cho hơn 100.000 nhân viên toàn cầu gây suy giảm hiệu năng và tăng tải vận hành.

– **Mô hình kiến trúc ZTNA áp dụng:** Google loại bỏ hoàn toàn hệ thống VPN truy cập từ xa và xây dựng kiến trúc Ủy nhiệm nhận biết định danh (*Identity-Aware Proxy*) theo mô hình *Client-initiated*:

1. *Kho quản lý thiết bị (Device Inventory Service):* Mọi máy trạm của nhân viên đều được cấp chứng thư số định danh lưu trong chip bảo mật phần cứng (TPM) và liên tục cập nhật trạng thái bản vá, cấu hình bảo mật (*Device Posture*).
2. *Cổng ủy nhiệm L7 (Access Proxy):* Toàn bộ ứng dụng nội bộ được đưa ra sau lớp Access Proxy kết hợp xác thực SSO và khóa bảo mật phần cứng chống lừa đảo (*Phishing-resistant MFA*).
3. *Động cơ kiểm soát truy cập (Access Control Engine):* Đánh giá đồng thời định danh người dùng, độ tin cậy thiết bị và phân loại độ nhạy cảm của ứng dụng đích trước khi cấp quyền cho từng phiên HTTP/HTTPS hoặc SSH.

– **Kết quả đạt được:** Hơn 100.000 nhân viên của Google có thể làm việc từ bất kỳ mạng Internet công cộng nào (quán cà phê, sân bay, tại nhà) với trải nghiệm truy cập ứng dụng tương đương mạng văn phòng mà không cần bật VPN, đồng thời cô lập hoàn toàn hạ tầng ứng dụng khỏi các cuộc tấn công quét mạng Tầng 3.

5.1.2. Quản lý kết nối trong môi trường Đa đám mây: Case Study Tập đoàn Siemens AG

Đối với các tập đoàn đa quốc gia vận hành song song Trung tâm dữ liệu nội bộ (*On-premises*) và nhiều nền tảng đám mây công cộng (AWS, Microsoft Azure), việc duy trì mạng đường trục MPLS và các đường hầm Site-to-Site VPN tạo ra cấu trúc định tuyến phức tạp. Quá trình chuyển đổi hạ tầng của tập đoàn công nghiệp **Siemens AG** là minh chứng thực tiễn cho việc ứng dụng ZTNA ở quy mô toàn cầu [5].

– **Bối cảnh và vấn đề gặp phải:** Siemens vận hành hạ tầng phục vụ hơn 300.000 nhân viên tại 190 quốc gia. Trước khi chuyển đổi, lưu lượng truy cập từ các chi nhánh và người dùng từ xa đều phải kéo về các trung tâm dữ liệu tập trung qua đường truyền MPLS và VPN (hiện tượng *Traffic Hairpinning*), gây độ trễ cao khi truy cập ứng dụng đám mây và tốn kém chi phí thuê kênh riêng. Đồng thời, hàng trăm địa chỉ IP công cộng của các cổng VPN và tường lửa biên bị lộ diện trên Internet, làm gia tăng bề mặt tấn công.

– **Mô hình kiến trúc ZTNA áp dụng:** Siemens triển khai nền tảng ZTNA gốc đám mây (Zscaler Private Access) theo mô hình phân bổ lai (*Hybrid Connectors*):

1. Đặt các bộ kết nối nhẹ (*App Connectors*) bên trong từng phân vùng mạng ảo (VPC/VNet) trên AWS, Azure và trung tâm dữ liệu nội bộ.
2. Đóng toàn bộ các cổng kết nối đi vào (*Inbound Ports*) trên tường lửa doanh nghiệp; các App Connector chỉ thiết lập kết nối đi ra (*Outbound-only*) qua cổng 443 tới đám mây ZTNA.
3. Định tuyến lưu lượng người dùng trực tiếp qua các nút Edge đám mây gần nhất tới đúng ứng dụng đích dựa trên tên miền FQDN.

– **Kết quả đạt được:** Siemens loại bỏ hoàn toàn các cổng dịch vụ lộ diện công cộng của ứng dụng nội bộ (*Dark Cloud*), triệt tiêu nguy cơ lây lan mã độc giữa các phân vùng đám mây và giảm đáng kể chi phí vận hành đường truyền MPLS truyền thống.

5.1.3. Cấp quyền cho Nhà thầu và Chống chiếm đoạt tài khoản: Case Study Cloudflare

Việc cấp quyền truy cập cho đối tác bên ngoài, nhà thầu hoặc nhân viên sử dụng thiết bị cá nhân (*BYOD*) luôn tiềm ẩn nguy cơ rò rỉ thông tin xác thực. Quá trình triển

khai nội bộ giải pháp **Cloudflare Access** tại chính công ty Cloudflare đã chứng minh hiệu quả thực tế của mô hình ZTNA trước các cuộc tấn công lừa đảo tinh vi [**?**].

- **Bối cảnh và vấn đề gặp phải:** Đội ngũ kỹ sư và các nhà thầu đối tác của Cloudflare phân tán toàn cầu, thường xuyên cần truy cập vào các hệ thống phát triển nội bộ nhạy cảm (kho mã nguồn Git, Jira, Jenkins, máy chủ SSH). Hệ thống VPN cũ gặp khó khăn trong việc phân tách quyền chi tiết cho từng nhà thầu thời vụ và không thể ngăn chặn kẻ tấn công xâm nhập nếu thông tin đăng nhập bị đánh cắp qua Phishing.
- **Mô hình kiến trúc ZTNA áp dụng:** Cloudflare thay thế VPN bằng lớp Ủy nhiệm ngược nhận biết định danh (*Identity-Aware Reverse Proxy*) kết hợp hai cơ chế bảo vệ cốt lõi:
  1. *Truy cập không tác nhân qua trình duyệt (Agentless Web/HTML5 Isolation):* Nhà thầu và đối tác truy cập ứng dụng Web hoặc giao diện dòng lệnh SSH trực tiếp qua trình duyệt được kiểm soát chính sách, không cần cài đặt phần mềm VPN trên máy cá nhân và chỉ được cấp quyền tạm thời theo từng dự án.
  2. *Xác thực phần cứng FIDO2 kết hợp mTLS:* Mọi phiên truy cập qua ZTNA Proxy đều bắt buộc xác thực bằng khóa bảo mật vật lý chuẩn FIDO2/WebAuthn (YubiKey) gắn liền với chứng thư số trên thiết bị được công ty cấp phát.
- **Kết quả thực tế (Ngăn chặn chiến dịch tấn công Oktapus năm 2022):** Vào tháng 7/2022, nhóm tin tặc thực hiện chiến dịch Phishing quy mô lớn (*Oktapus*) nhắm vào hơn 130 tổ chức công nghệ thông qua tin nhắn SMS giả mạo trang đăng nhập SSO. Mặc dù 3 nhân viên của Cloudflare đã nhập tên đăng nhập và mật khẩu vào trang giả mạo, kẻ tấn công vẫn bị chặn đứng hoàn toàn ở lớp ZTNA Access Proxy do không sở hữu khóa mật mã phần cứng FIDO2 và chứng thư định danh thiết bị hợp lệ, bảo vệ an toàn tuyệt đối cho hệ thống nội bộ [**?**].

5.2. Thách thức và Rào cản kỹ thuật khi triển khai

5.2.1. Vấn đề tương thích với các ứng dụng cũ và giao thức phi web (Legacy Applications)

Một trong những rào cản kỹ thuật lớn nhất khi chuyển đổi từ VPN sang ZTNA là sự hiện diện của các hệ thống ứng dụng kế thừa (*Legacy Applications*) được thiết kế từ trước kỷ nguyên điện toán đám mây:

- **Hạn chế của mô hình Reverse Proxy với giao thức phi HTTP:** Các ứng dụng doanh nghiệp truyền thống (như hệ thống ERP/SAP cũ, phần mềm kế toán nội bộ, hệ thống tổng đài VoIP/SIP hoặc giao thức truyền tệp FTP chủ động) thường vận hành trên các cổng TCP/UDP tùy biến, sử dụng dải cổng động (*Dynamic RPC*

Bảng 5.1.

5.2: Tổng hợp đối chiếu các nghiên cứu tình huống triển khai ZTNA thực tế

Case Study thực tế	Kịch bản & Quy mô	Mô hình ZTNA áp dụng	Hiệu quả bảo mật trọng tâm
Google BeyondCorp	Lao động kết hợp (>100.000 nhân viên)	Client-initiated (Access Proxy + Device Inventory)	Xóa bỏ hoàn toàn VPN, cô lập mạng L3, xác thực theo ngữ cảnh thiết bị.
Siemens AG	Hạ tầng Đa đám mây (>300.000 nhân viên)	Hybrid Cloud-Broker (Outbound Connectors)	Đóng toàn bộ cổng Inbound, giảm trễ định tuyến, thay thế kênh MPLS/VPN.
Cloudflare	Nhà thầu, BYOD & Chống Phishing nội bộ	Service-initiated Reverse Proxy + FIDO2 mTLS	Cấp quyền vi mô cho đối tác, chặn đứng thực tế chiến dịch Phishing Oktapus.

Ports) hoặc nhúng cứng địa chỉ IP trong mã nguồn thay vì sử dụng tên miền FQDN. Mô hình ZTNA không tác nhân (*Agentless*) vốn chỉ hỗ trợ HTTP/HTTPS sẽ không thể xử lý các lưu lượng này.

– **Luồng kết nối khởi tạo từ máy chủ (*Server-initiated Flows*):** Kiến trúc ZTNA tiêu chuẩn chỉ hỗ trợ luồng giao tiếp một chiều khởi tạo từ phía người dùng (*Client-to-Server*). Các hệ thống giám sát hạ tầng, đẩy bản vá tự động hoặc dịch vụ gọi ngược từ máy chủ về máy trạm (*Server-to-Client Callbacks*) đòi hỏi doanh nghiệp phải triển khai các tác nhân ZTNA hỗ trợ định tuyến hai chiều ở Tầng 4 hoặc duy trì phân đoạn mạng chuyển tiếp tạm thời trong giai đoạn quá độ.

5.2.2. Độ phức tạp khi tích hợp với hạ tầng định danh hiện hữu (Active Directory, LDAP, IAM)

ZTNA lấy định danh làm ranh giới bảo mật cốt lõi; do đó, hiệu quả của ZTNA phụ thuộc trực tiếp vào mức độ trưởng thành của hệ thống Quản lý định danh và Truy cập (*IAM*) sẵn có:

– **Phân mảnh kho định danh (*Identity Silos*):** Nhiều tổ chức duy trì đồng thời hệ thống Active Directory (AD) cục bộ cho các ứng dụng nội bộ, thư mục LDAP cho máy chủ Linux và các nhà cung cấp định danh đám mây (như Microsoft Entra ID, Okta) cho ứng dụng SaaS. Việc đồng bộ hóa thuộc tính người dùng, nhóm quyền và trạng thái vô hiệu hóa tài khoản theo thời gian thực giữa các hệ thống này đòi hỏi công sức tích hợp phức tạp qua các giao thức SAML 2.0, OIDC và SCIM.

– **Thiếu hụt dữ liệu đo lường từ thiết bị (*Telemetry Gaps*):** Để động cơ đánh giá tin cậy (*Trust Engine*) đưa ra quyết định chính xác, ZTNA Controller phải kết nối API với các hệ thống quản lý thiết bị (MDM/UEM) và giải pháp phát hiện phản hồi điểm cuối (EDR). Nếu doanh nghiệp chưa chuẩn hóa việc định danh thiết bị bằng chứng thư số PKI, hệ thống ZTNA sẽ gặp khó khăn trong việc phân biệt thiết bị hợp lệ với thiết bị giả mạo.

5.2.3. Rào cản văn hóa tổ chức, quy trình vận hành và thói quen người dùng

Bên cạnh các yếu tố công nghệ, yếu tố con người và cơ cấu tổ chức thường quyết định sự thành bại của dự án chuyển đổi Zero Trust:

– **Sự phân tách giữa các bộ phận kỹ thuật (*Organizational Silos*):** Trong mô hình truyền thống, đội ngũ Mạng (*Network Operations*) quản lý tường lửa và VPN, đội ngũ An toàn thông tin (*SecOps*) giám sát cảnh báo, còn đội ngũ Phát triển (*App Owners*) quản lý ứng dụng. Việc triển khai ZTNA buộc các bộ phận này phải phối hợp chặt chẽ để lập bản đồ luồng dữ liệu ứng dụng và xây dựng chính sách truy cập chi tiết đến từng chức năng.

– **Ma sát trải nghiệm và tâm lý kháng cự của người dùng:** Nếu các ngưỡng đánh giá tin cậy động được cấu hình quá khắt khe (ví dụ: yêu cầu xác thực MFA lặp lại liên tục khi người dùng chuyển đổi mạng Wi-Fi hoặc cập nhật trình duyệt), nhân viên sẽ nảy sinh tâm lý mệt mỏi xác thực (*MFA Fatigue*) và tìm cách lách quy trình bảo mật. Doanh nghiệp cần kết hợp truyền thông nội bộ và thiết lập chính sách chuyển đổi theo từng giai đoạn để giảm thiểu gián đoạn công việc.

5.3. Lộ trình 5 bước chuyển đổi sang Kiến trúc Zero Trust (ZTA)

Để tránh rủi ro gián đoạn hoạt động kinh doanh khi thay thế toàn bộ hạ tầng mạng cùng lúc, doanh nghiệp cần áp dụng phương pháp luận triển khai cuốn chiếu gồm 5 bước chuẩn hóa:

5.3.1. Bước 1: Định danh dữ liệu và tài sản quan trọng (Define the Protect Surface)

Thay vì cố gắng bảo vệ toàn bộ bề mặt tấn công (*Attack Surface*) rộng lớn và luôn biến đổi của toàn hệ thống, doanh nghiệp cần thu hẹp phạm vi tập trung vào các **Bề mặt**

cần bảo vệ (*Protect Surface*). Mỗi Protect Surface bao gồm các thành phần cốt lõi thuộc nhóm **DAAS**:

- **Dữ liệu (*Data*):** Dữ liệu định danh khách hàng (PII), thông tin thẻ thanh toán (PCI), sở hữu trí tuệ, bí mật kinh doanh.
- **Ứng dụng (*Applications*):** Các phần mềm lõi phục vụ vận hành như ERP, CRM, Core Banking, hệ thống quản lý nhân sự.
- **Tài sản (*Assets*):** Hệ thống máy chủ cơ sở dữ liệu, thiết bị điều khiển công nghiệp (SCADA/IoT), điểm bán hàng.
- **Dịch vụ (*Services*):** Các dịch vụ hạ tầng nền tảng như DNS, DHCP, Active Directory, dịch vụ NTP.

Mỗi Protect Surface có quy mô nhỏ, xác định được và hoàn toàn nằm trong tầm kiểm soát của tổ chức, giúp việc thiết lập ranh giới bảo mật trở nên khả thi.

5.3.2. Bước 2: Vẽ bản đồ luồng giao tiếp dữ liệu (Map the Transaction Flows)

Sau khi xác định được Protect Surface ưu tiên, đội ngũ kỹ thuật tiến hành phân tích luồng lưu lượng mạng thực tế để hiểu rõ cách thức các thành phần tương tác với nhau:

- Thu thập nhật ký lưu lượng từ tường lửa, bộ chuyển mạch, hệ thống giám sát mạng (NetFlow) và nhật ký xác thực ứng dụng.
- Xác định chính xác nhóm người dùng nào, thiết bị nào, dịch vụ phụ trợ nào đang giao tiếp với tài sản trong Protect Surface, sử dụng giao thức gì và tần suất ra sao. Kết quả của bước này là sơ đồ phụ thuộc ứng dụng (*Application Dependency Mapping*), giúp loại bỏ các luồng kết nối dư thừa không phục vụ nghiệp vụ.

5.3.3. Bước 3: Thiết kế kiến trúc mạng Zero Trust xung quanh tài sản (Architect a Zero Trust Network)

Dựa trên bản đồ luồng giao tiếp đã lập, kiến trúc sư hệ thống bố trí các điểm thực thi chính sách (*Policy Enforcement Points - PEP*) bao bọc sát xung quanh từng Protect Surface để tạo thành các vi chu vi (*Micro-perimeters*):

- Triển khai ZTNA Gateway hoặc ZTNA Connector ngay phía trước máy chủ ứng dụng, đóng toàn bộ các cổng kết nối trực tiếp từ bên ngoài.
- Tích hợp mặt phẳng kiểm soát (ZTNA Controller) với hệ thống quản lý định danh tập trung (IdP/SSO) và các nguồn dữ liệu ngữ cảnh thiết bị (EDR/MDM) để sẵn sàng thực thi cơ chế xác thực trước khi kết nối.

5.3.4. Bước 4: Xây dựng tập chính sách Zero Trust (Create the Zero Trust Policy)

Ở bước này, các quy tắc kiểm soát truy cập chi tiết dựa trên thuộc tính (ABAC) được thiết lập theo nguyên tắc đặc quyền tối thiểu (*Least Privilege*). Để đảm bảo chính sách không bỏ sót ngữ cảnh, tập quy tắc được xây dựng dựa trên **Phương pháp luận Kipling** gồm 6 tham số:

1. **Ai (*Who*):** Định danh người dùng hoặc nhóm vai trò cụ thể được phép truy cập (xác thực qua IdP).
2. **Cái gì (*What*):** Ứng dụng, API hoặc phân vùng dữ liệu đích cụ thể trong Protect Surface.
3. **Khi nào (*When*):** Khung thời gian hoặc thời hạn phiên làm việc được phép truy cập.
4. **Ở đâu (*Where*):** Vị trí địa lý, phân vùng mạng nguồn hoặc trạng thái bảo mật của thiết bị đầu cuối (*Device Posture*).
5. **Tại sao (*Why*):** Mục đích nghiệp vụ hợp lệ giải trình cho nhu cầu truy cập tài nguyên nhạy cảm.
6. **Như thế nào (*How*):** Giao thức truyền tải bắt buộc (ví dụ: chỉ cho phép HTTPS với mTLS, yêu cầu kiểm tra mã độc thời gian thực).

Mọi lưu lượng không khớp với tập chính sách Kipling đã định nghĩa đều bị chặn mặc định (*Implicit Deny*).

5.3.5. Bước 5: Giám sát, phân tích và cải tiến liên tục (Monitor and Maintain)

Triển khai Zero Trust là một chu trình lặp liên tục chứ không phải một dự án tĩnh kết thúc sau khi cài đặt:

– Toàn bộ nhật ký truy cập Tầng 7, sự kiện cấp/thu hồi phiên và dữ liệu viễn trắc thiết bị từ hệ thống ZTNA được đẩy tập trung về nền tảng SIEM/SOAR.

– Đội ngũ vận hành an ninh thường xuyên rà soát các chính sách truy cập không còn sử dụng (*Unused Policies*), tinh chỉnh ngưỡng điểm tin cậy, sau đó lặp lại quy trình từ Bước 1 cho Protect Surface tiếp theo cho đến khi toàn bộ hạ tầng doanh nghiệp được chuyển đổi hoàn toàn.

5.4. Xu hướng hội tụ công nghệ tương lai

5.4.1. Khung kiến trúc SASE (Secure Access Service Edge) và SSE (Security Service Edge)

Sự phân tán của người dùng và ứng dụng đám mây thúc đẩy xu hướng hợp nhất hạ tầng mạng diện rộng và các dịch vụ bảo mật thành một nền tảng đám mây duy nhất, được định nghĩa thông qua hai khung kiến trúc chiến lược:

– **Secure Access Service Edge (SASE):** Là kiến trúc hội tụ giữa công nghệ mạng định nghĩa bằng phần mềm (**SD-WAN**) và bộ dịch vụ bảo mật gốc đám mây (**SSE**), được phân phối trực tiếp từ mạng lưới các nút Edge phân tán toàn cầu. SASE cho phép doanh nghiệp định tuyến lưu lượng tối ưu đồng thời áp dụng chính sách bảo mật nhất quán tại điểm gần người dùng nhất.

– **Security Service Edge (SSE):** Đóng vai trò là trụ cột an toàn thông tin của kiến trúc SASE, tập trung vào việc hợp nhất toàn bộ các năng lực kiểm soát truy cập và bảo vệ dữ liệu đám mây trên một mặt phẳng quản trị thống nhất, bao gồm ba thành phần nòng cốt: **ZTNA**, **CASB** và **SWG**.

5.4.2. Tích hợp hợp nhất ZTNA với CASB và SWG

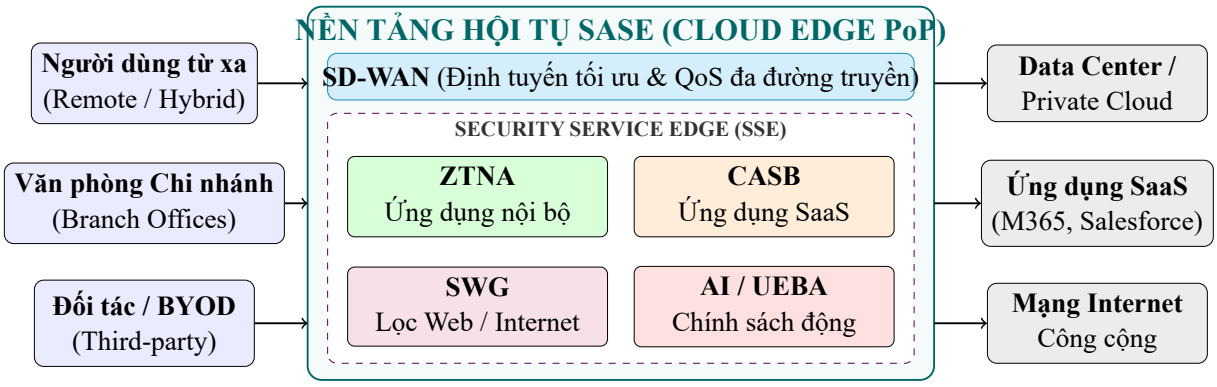
Trong hệ sinh thái SSE hiện đại, ZTNA không hoạt động đơn lẻ mà tích hợp chặt chẽ với hai công nghệ bảo mật biên đám mây khác để bao phủ toàn diện mọi hướng lưu lượng của người dùng:

– **ZTNA (Kiểm soát ứng dụng riêng tư):** Đảm nhiệm việc bảo vệ và cấp quyền truy cập vi mô tới các ứng dụng nội bộ đặt tại trung tâm dữ liệu riêng hoặc hạ tầng đám mây cá nhân (Private Cloud/IaaS).

– **CASB (*Cloud Access Security Broker*):** Kiểm soát các ứng dụng đám mây công cộng được doanh nghiệp cấp phép (Sanctioned SaaS như Microsoft 365, Salesforce, Google Workspace), phát hiện ứng dụng đám mây trái phép (*Shadow IT*) và thực thi chống thất thoát dữ liệu (DLP) ở cấp độ API.

– **SWG (*Secure Web Gateway*):** Đảm nhiệm lọc lưu lượng truy cập Internet công cộng, phân loại URL độc hại, giải mã kiểm tra lưu lượng TLS và ngăn chặn mã độc từ các trang web bên ngoài.

Sự hợp nhất này giúp người dùng chỉ cần cài đặt một tác nhân hợp nhất duy nhất (*Unified Agent*) trên thiết bị đầu cuối, trong khi quản trị viên vận hành một bộ chính sách bảo mật đồng nhất cho cả ứng dụng nội bộ, ứng dụng SaaS và truy cập Web.



5.2: Mô hình kiến trúc hội tụ SASE và hợp nhất các thành phần bảo mật SSE

Hình 5.2.

5.4.3. Ứng dụng AI/ML và Phân tích hành vi người dùng (UEBA) trong điều chỉnh chính sách động

Trong các thế hệ giải pháp ZTNA tiếp theo, trí tuệ nhân tạo (AI), học máy (ML) và phân tích hành vi người dùng và thực thể (**UEBA** - *User and Entity Behavior Analytics*) được tích hợp sâu vào động cơ đánh giá tin cậy nhằm chuyển dịch từ kiểm soát dựa trên quy tắc tĩnh sang phòng thủ thích ứng tự động:

– **Xây dựng hồ sơ hành vi cơ sở (*Behavioral Baselining*):** Các mô hình học máy không giám sát phân tích dữ liệu lịch sử về khung giờ làm việc, vị trí địa lý đăng nhập, thiết bị quen dùng, tốc độ gõ phím và tần suất truy xuất dữ liệu của từng người dùng để thiết lập hồ sơ hành vi chuẩn mực.

– **Phát hiện bất thường theo thời gian thực:** Hệ thống UEBA liên tục đối chiếu hành vi hiện tại với đường cơ sở để nhận diện các chỉ báo xâm nhập tinh vi mà quy tắc truyền thống bỏ sót, chẳng hạn như hiện tượng di chuyển bất khả thi (*Impossible Travel*), truy xuất hàng loạt tệp tin nhạy cảm ngoài giờ hành chính hoặc chuỗi gọi API bất thường từ một tài khoản đã xác thực hợp lệ.

– **Tự động hóa phản ứng chính sách (*Autonomous Policy Adaptation*):** Khi thuật toán phát hiện mức độ rủi ro tăng đột biến, điểm tin cậy T_{score} lập tức bị hạ thấp. Hệ thống tự động kích hoạt quy trình phản ứng theo cấp độ: yêu cầu xác thực sinh trắc học bổ sung, giới hạn quyền chỉ đọc (*Read-only*), cô lập phiên vào môi trường trình duyệt ảo từ xa (*Remote Browser Isolation - RBI*) hoặc chấm dứt hoàn toàn phiên kết nối mà không cần chờ quản trị viên can thiệp thủ công.

Tài liệu tham khảo

Tiếng Anh

[1] National Institute of Standards and Technology (NIST), *Zero Trust Architecture*, NIST Special Publication 800-207, 2020. DOI: 10.6028/NIST.SP.800-207.

[2] A. Kerman, O. Borchert, S. Rose, et al., *Implementing a Zero Trust Architecture*, NIST Special Publication 1800-35, National Cybersecurity Center of Excellence (NCCoE), 2025. DOI: 10.6028/NIST.SP.1800-35.

[3] Cloud Security Alliance (CSA), *Software-Defined Perimeter (SDP) Specification Version 2.0*, Cloud Security Alliance Technical Report, 2022.

[4] Cybersecurity and Infrastructure Security Agency (CISA), *Zero Trust Maturity Model Version 2.0*, CISA Industrial Guidance, 2023.

[5] A. McQuaid, N. MacDonald, J. Watts, and S. Handa, *Market Guide for Zero Trust Network Access*, Gartner Research Report G00730534, 2022.

[6] C. Canales, J. D'Hoinne, T. Bartley, and A. Lerner, *Market Guide for Security Service Edge*, Gartner Research Report, 2023.

[7] G. Finney and J. Kindervag, *Project Zero Trust: A Story about a Strategy for Aligning Security and the Business*, John Wiley & Sons, 1st Edition, 2022.

[8] E. Gilman and D. Barth, *Zero Trust Networks: Building Secure Systems in Untrusted Networks*, O'Reilly Media, 1st Edition, 2017.

[9] V. Mavroudis, *Zero-Trust Network Access (ZTNA): Architecture, Mechanics and Deployment Topologies*, arXiv preprint arXiv:2410.20611, 2024.